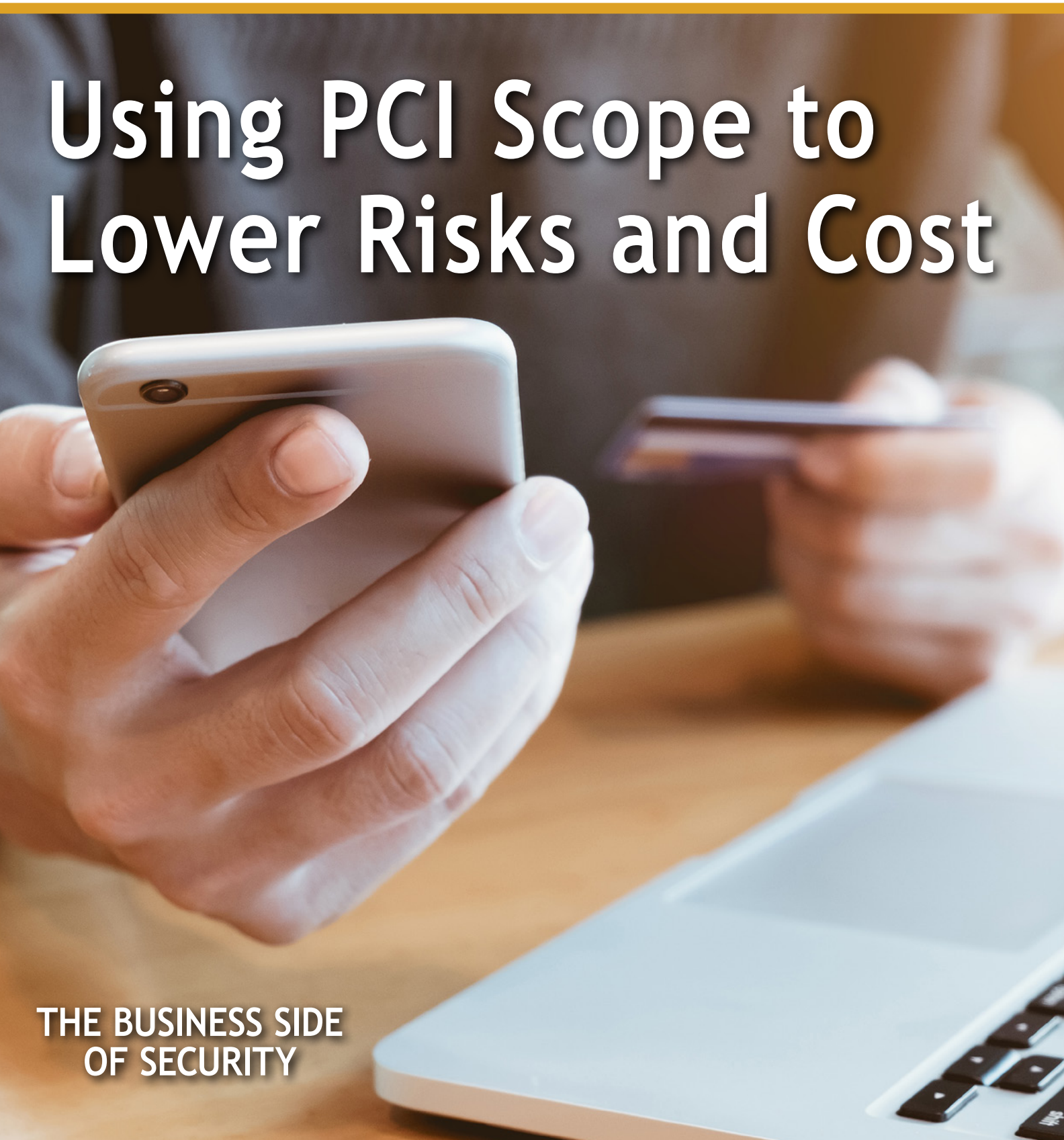
ISSA JOURNAL

October 2020
Volume 18 Issue 10

Cyber Risk Management: Strategic Plan or Afterthought?
Surveying Five Years of Java Deserialization CVEs
Quantitative Risk Calculation in Cybersecurity: The Value of Quantifying Risk
Python Programming: Object-Oriented Programming

Using PCI Scope to Lower Risks and Cost



THE BUSINESS SIDE OF SECURITY

Table of Contents

DEVELOPING AND CONNECTING CYBERSECURITY LEADERS GLOBALLY

Feature

12 Using PCI Scope to Lower Risks and Cost

By R. Scott Pierangelo and David Lam

This article discusses leveraging technology identified in PCI Self-Assessment Questionnaires A and P2PE to reduce the risks and costs to an organization when processing credit cards, which also subjects the organization to fewer and less onerous compliance requirements. By leveraging newer technology and risk transfer, organizations can in some cases reduce questions almost tenfold.

18 Cyber Risk Management: Strategic Plan or Afterthought?

By Mark Langford – ISSA member, North Texas Chapter

This article discusses the current state of cyber risk management and the emerging factors that will motivate organizations to invest sufficiently in their cyber defenses to protect their vital data assets.

22 Surveying Five Years of Java Deserialization CVEs

By Erik Elbieh – ISSA member, New Jersey Chapter

A dramatic increase in Java deserialization CVEs has occurred since research in 2015 highlighted a high-impact vulnerability class that has since been found in many widely used applications. This paper examines the progress made in identifying these Java deserialization vulnerabilities and uses a custom CVE dataset to extrapolate the trajectory of this vulnerability class over the next few years.

28 Quantitative Risk Calculation in Cybersecurity: The Value of Quantifying Risk

By Chris van den Hooven – ISSA member, Netherlands Chapter

This article advocates for the intrinsic value of quantitative decision-making in cybersecurity.

36 Python Programming: Object-Oriented Programming

By Constantinos Doskas – ISSA Senior Member, Northern Virginia Chapter

This article is an introduction to object-oriented technology. Python is an object-oriented language. Up to this point we have used many of the objects provided by Python, although our programming approach was procedural. What is object-oriented programming? Why was it developed? Why do we want to use it? These are questions that will be answered in this and the next few articles.

Also in this Issue

3 ..... **From the President**

5 ..... **Sabett's Brief**
To Enable or Not to Enable…That's No Longer a Question

6 ..... **Women in Cybersecurity**
Meet the Next Generation of Cybersecurity Women

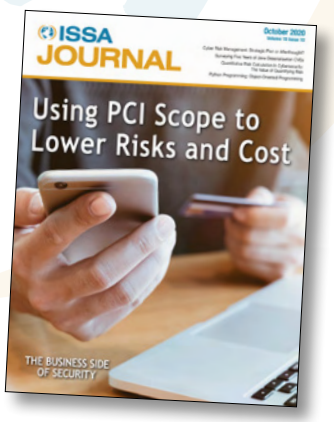
7 ..... **The Cryptic Curmudgeon**
Security, and Business, Metrics

8 ..... **Herding Cats**
Shut Up and Take My Money!

9 ..... **Security in the News**

10 ..... **Association News**

39 ..... **Career Center**



©2020 Information Systems Security Association, Inc. (ISSA)

The ISSA Journal (1949-0550) is published monthly by
Information Systems Security Association
1964 Gallows Road, Suite 210, Vienna, VA 22182
+1 (703) 382-8205 (local/international)

Hello Fellow ISSA Members



Candy Alexander, International President

As we enter into the fall season, many of us are settling into somewhat regular routines, and so has ISSA International. In September, we held the ISSA International meeting, which was well received, and we saw a huge increase in member registrations and attendance—an increase of nearly 120 percent! This type of response is extremely motivating to us at headquarters; it demonstrates that our members care! Thank you!

As a brief recap of the annual meeting: Pamela Fusco reviewed the financials of the Association's 2019 fiscal year; Executive Director Marc Thompson and I presented highlights of the Association's 2020 accomplishments to date, some of which included chapter growth, an update on membership, and expanded benefits to add value for membership. I encourage all of our members who may not have been able to attend the meeting to watch/listen to the recording.

One of the main reasons of our annual meeting is to officially establish the International Board, with both newly elected/re-elected Board members along with seated Board members. I am so very excited to work with the 2020/2021 Board, which promises to be a group of highly energetic and motivated individuals. Please check out who these folks are and do not hesitate to reach out to any of them, or me for that matter! Emails are available on the ISSA.org website, under International Board, which can be found under the "About" tab.

The fall season also brings with it the ISSA business planning cycle in earnest. We have been using the standard process/practice of establishing/reviewing our strategic goals, which in turn Marc Thompson and his support team develop an operational plan to carry out. Once both are approved by the International Directors, a fiscally responsible budget (i.e., not spending more than we have) is developed to support our plans and initiatives. Sounds rather basic, and it is. It is solid and keeps us focused and on course.

I shared one strategic theme at the annual meeting that we have floated around informally (Board hasn't approved of it yet): "2021 is the Year of Member Engagement." That means we need YOU to get involved in our Association. We need you to join our committees to help develop the content and programming that we need to share our knowledge between our members. We need YOU to help make ISSA relevant to your needs, and what better way to do this than to get involved and express those needs.

I have received reports that our web conferences are extremely successful, with huge numbers of people registering and attending. The ratings are averaging a 5 out of 5, which is unheard of on a sustained basis. In addition, our LinkedIn discussion group is extremely active with thousands of followers. I offer these points because I know folks are interested with what we have to say – however not all are members. AND, most of these engagements/interactions are one-way communications.

The real value of the ISSA for our members is the interchange of knowledge. This occurs through networking and conversations. Granted, one could argue that both web conferences and LinkedIn offer interchange – they are very limited. I am hoping that we can expand into other unconventional-to-the-ISSA methods of interchange, methods such as knowledge sharing and interchange using our member-only portal as well as a couple of others that we will announce shortly.

It is important for our members to realize that the value of our membership doesn't just come from receiving. The real value is through giving—or should I say volunteering? Many of our members have gained an incredible amount of knowledge and experience through volunteering: for example, starting at the chapter assisting with lining up speakers or setting up meeting facilities, to running for Chapter offices and the International Board. Just ask some of those who have volunteered for our association, and I am confident that they will tell you of the incredible experiences and skills that can be obtained just by volunteering.

I will leave you with those thoughts. Until next month, please stay safe and healthy.

Respectfully,

Candy Alexander, CISSP CISM
ISSA International President
Candy.Alexander@ISSA.org

DEVELOPING AND CONNECTING CYBERSECURITY LEADERS GLOBALLY

ISSA
Information Systems Security Association

International Board Officers

President
Candy Alexander
Distinguished Fellow

Vice President
Deb Peinert
CISSP, ISSM

Secretary/Director of Operations
Shawn Murray, C|CISO, CISSP, CRISC, FITSP-A, C|EI, Fellow

Treasurer/Chief Financial Officer
Pamela Fusco
Distinguished Fellow

Board of Directors

Betty Burke, CISSP, CISA
Bill Danigelis, Honor Roll, Senior Member
Curtis Campbell, C|CISO
Mary Ann Davidson
Distinguished Fellow
Alex Grohmann
CISSP, CISA, CISM, CIPT, Fellow
Rob Martin, CISSP, Senior Member
Jimmy Sanders
Michael Rasmussen
David Vaughn, C|CISO, CISSP, LPT, GSNA, Senior Member

Information Systems Security Association
1964 Gallows Road, Suite 310, Vienna, VA 22182
+1 (703) 382-8205 (local/international)

The Information Systems Security Association, Inc. (ISSA)® is a not-for-profit, international organization of information security professionals and practitioners. It provides educational forums, publications and peer inte raction opportunities that enhance the knowledge, skill and professional growth of its members.

With active participation from individuals and chapters all over the world, the ISSA is the largest international, not-for-profit association specifically for security professionals. Members include practitioners at all levels of the security field in a broad range of industries, such as communications, education, healthcare, manufacturing, financial, and government.

The ISSA international board consists of some of the most influential people in the security industry. With an international communications network developed throughout the industry, the ISSA is focused on maintaining its position as the preeminent trusted global information security community.

The primary goal of the ISSA is to promote management practices that will ensure the confidentiality, integrity and availability of information resources. The ISSA facilitates interaction and education to create a more successful environment for global information systems security and for the professionals involved.

ISSA JOURNAL

Now Indexed with EBSCO

Editor: Thom Barrie
editor@issa.org

Advertising: vendor@issa.org

Editorial Advisory Board

James Adamson
Jack Freund, Senior Member
Michael Grimaila, Fellow
Sandeep Jayashankar
Yvette Johnson
John Jordan, Senior Member
Steve Kirby – Chairman
Joe Malec, Fellow
Ravi Muthukrishnan
Abhinav Singh
Kris Tanaka
Joel Weise,
Distinguished Fellow

Services Directory

Website
webmaster@issa.org

Chapter Relations
chapter@issa.org

Member Relations
memberservices@issa.org

Executive Director
execdir@issa.org

Advertising and Sponsorships
vendor@issa.org

The information and articles in this magazine have not been subjected to any formal testing by Information Systems Security Association, Inc. The implementation, use and/or selection of software, hardware, or procedures presented within this publication and the results obtained from such selection or implementation, is the responsibility of the reader.

Articles and information will be presented as technically correct as possible, to the best knowledge of the author and editors. If the reader intends to make use of any of the information presented in this publication, please verify and test any and all procedures selected. Technical inaccuracies may arise from printing errors, new developments in the industry, and/or changes/enhancements to hardware or software components.

The opinions expressed by the authors who contribute to the ISSA Journal are their own and do not necessarily reflect the official policy of ISSA. Articles may be submitted by members of ISSA. The articles should be within the scope of information systems security, and should be a subject of interest to the members and based on the author's experience. Please call or write for more information. Upon publication, all letters, stories, and articles become the property of ISSA and may be distributed to, and used by, all of its members.

ISSA is a not-for-profit, independent corporation and is not owned in whole or in part by any manufacturer of software or hardware. All corporate information security professionals are welcome to join ISSA. For information on joining ISSA and for membership rates, see www.issa.org.

All product names and visual representations published in this magazine are the trademarks/registered trademarks of their respective manufacturers.

To Enable or Not to Enable…That's No Longer a Question



By Randy V. Sabett – ISSA Distinguished Fellow, Northern Virginia Chapter

If you had asked me 15 years ago how many companies would openly and proactively use cybersecurity as a business enabler, I would have said "I can count that on one hand." Now, in 2020, companies use cyber as a business enabler on a frequent basis and, some might say, it's no longer an option. As just one data point, earlier this year a company had its lawyer (a) engage a cybersecurity service provider to perform a compromise assessment and (b) produce a confidential but non-privileged summary report of the results of the assessment to be used with customers and potential customers of the company… and this was all being done proactively, not in response to a breach.

The company had previously created an integrated set of cybersecurity policies and standards, including a cybersecurity policy and an incident response plan. Their goal was to have security and privacy be a distinguishing feature over its competitors and a business enabler, not a barrier, to expansion. In addition, it sought to make its improved security platform an enabler of the use of emerging technologies. For example, the company has on its road map the use of machine learning platforms to better adapt to cyber attacks it is facing.

At a broader level, we have for years known that good cyber hygiene can significantly limit exposure to threats and vulnerabilities, enhance incident response, and accelerate acceptance, including at a budgetary level, of a damaging event. Forward-leaning companies with such good cyber hygiene have controls and systems in place to attempt to stay ahead of cyber threats. When this type of approach to cybersecurity is embraced by the company as a business enabler, it can provide a variety of benefits, including increasing customer confidence and internal morale of the security team, since they feel more valued and better understood.

Historically, many organizations hesitated to speak openly about their cybersecurity posture due to legitimate concerns about liability or damage to their reputation. Many also feared they might wind up being overly scrutinized by the government. What's interesting about the view of cybersecurity being a business enabler is that it also fits well with the notion of defend forward espoused by the US government. Defend forward is the unclassified and publicly communicated cyber policy that contemplates taking the fight against the cyber attackers (of all types) outside of the network that is being defended and using whatever legal means are necessary to raise the cost to our adversaries of attacking our systems. It is not synonymous with active defense, though that could be a part of a defend forward strategy. Ultimately, defend forward will require coordination by a variety of diverse public and private sector entities if we are to be successful.

In light of the amount of network infrastructure not controlled by the government, defend forward necessarily must involve the private sector. Specifically, in order for a defend-forward approach to work, not only must there be improvements in information sharing and public/private partnerships, there must also exist more open dialog about security posture. Enter the idea of cybersecurity as a business enabler. If companies can get comfortable with cybersecurity as a business enabler by, for example, talking with an appropriate level of transparency about how they defend their sensitive information and assets, that can naturally extend into a defend-forward strategy.

Ultimately, if companies can overcome their fears about sharing cyber information with each other, a "sum of the parts is greater than the whole" attitude can take shape. I've seen this firsthand with a very forward-thinking industry group with whom I work. Several of their CISOs established their own information sharing and analysis organization (ISAO) out of necessity and desire, not because they were told to do so. Many of their companies now use cybersecurity as a business enabler. It CAN work!

On that note, I'm off to awaken my three dogs who have now gotten so used to me being at home that they sleep through most of conference calls and commutes to the kitchen to grab lunch (and my reading aloud of this column). Have a great National Cybersecurity Awareness Month and a scary Halloween. And just FYI, I'm dressing my dogs as hackers this year…

About the Author

Randy V. Sabett, J.D., CISSP, is an attorney with Cooley LLP (www.cooley.com/rsabett), a member of the advisory boards of the Georgetown Cybersecurity Law Institute and the RSA Selection Committee, and is the former Senior VP of ISSA NOVA. He has completed FBI Citizen Academy training, was a member of the Commission on Cybersecurity for the 44th Presidency, was named ISSA Professional of the Year for 2013 and an ISSA Distinguished Fellow in 2018, and can be reached at rsabett@cooley.com.



Meet the Next Generation of Cybersecurity Women

By Curtis C. Campbell – ISSA Senior Member, Chattanooga Chapter

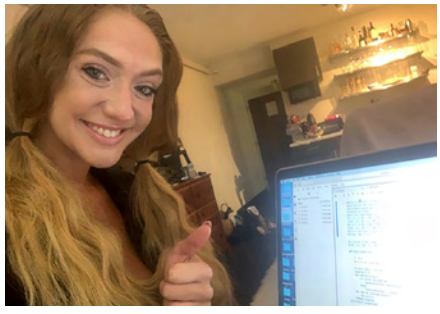
Meet Joanna Rachel and Yatri Patel, two undergraduate computer science majors who are living proof there is no shortage of rising female cybersecurity talent. Growing up continents apart but working towards bachelor of science degrees in computer science at the same university, these brilliant young women have traveled different paths to get here. In this exclusive interview, Joanna and Yatri represent the face of the next generation who are raising the bar for women's diversity and inclusion.

Joanna Rachel and Yatri Patel started young, wasting no time in finding their passion. Separated by oceans and different cultures (Joanna grew up in America and Yatri in India), both were raised with the belief they could raise the bar in any field they chose. With graduation on the horizon, Joanna and Yatri reflect on what attracted them to a (formerly) male-dominated field of computer science and how they are inspiring other young women to do the same.

These two bright young female computer science majors illustrate a refreshing, new generation of talent making a difference and moving the needle toward diversity and inclusion for women. Joanna, born and raised in America, had little exposure to computer science or STEM courses early on and had no inkling there were gender discrepancies until she was older and noticed a divergence among genders. Yatri, born and raised in India, had early exposure to cybersecurity and computer science but had never learned of a woman making contributions in the field of computer science until she went to college.

I asked them to share their insights and influences, passions and dreams, and educational paths and experiences to provide readers with a glimpse of the next generation of talent, preparing soon to work alongside us.

Joanna's story



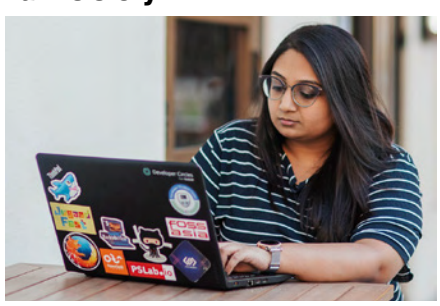
I did not envision myself in cybersecurity growing up, although in retrospection it would make sense, seeing as I found more of a fascination with my computer growing up then I did my actual homework.

It all started when I was about the age of four, when my older brother offered me a Sega Genesis as my mother attempted to wrangle my four other siblings together. I can only imagine it was given to keep me quiet. I remember the fuzzy, blue "Sega" sign that used to pop up on the screen. I wondered what made these characters move and who told them what to do? I was overwhelmed by this tiny contraption. It wasn't till later on in life that I actually decided to figure out how computers worked, and that was the start of the journey into the field of computer science.

I did not have any STEM courses in middle or high school and little experience early on, but I wish I would have. Learning this subject is much like another language, and the more experience you have, the easier things come to you. I did, however, have a knack for math early on though little coding/computer experience. Yet, I found ways to hack into my old computers and envisioned each bypass as a challenging puzzle. It wasn't until later on in life that I actually decided to formally figure out how computers worked, and that was the start of the journey into the field of computer science (as I never seemed to be able to put the Sega Genesis away)!

I was raised by a mom who didn't really teach me about gender discrepancies. In fact, I was raised to think women could do whatever they wanted better than men. When I got older, I noticed the divergence among the sexes and heard the passive-aggressive comments people tend to make about women who like math and computers. I had always been fascinated with science. My early aspirations were to be a nurse. I had gone to nursing school at first, and while nursing is an amazing field, I wanted to focus solely on science. So I took two years off, and decided to come back to school for a computer science degree."

Yatri's story



My early influences were surely the old Mario games. I had two Nintendo Game Boys, and actually I still have them. I was very intrigued by them in my child-

Continued on page 33

Security, and Business, Metrics



By Robert Slade

Security supports business. Security is business and requires management. And, as the old mantra has it, you can't manage what you can't measure. In security, we tend to refer to the measurements we make of things and situations as metrics. We tend to give lip service to metrics, saying that they are important (like auditors), but in reality we often try to avoid them whenever we can. We often measure the wrong things. One of the common examples of incorrect metrics is that almost all of us will measure the number of computer viruses that a scanning platform catches. However, the more important number is how many viruses it fails to detect.

One of the most helpful books in the metrics literature is *PRAGMATIC Security Metrics* by W. Krag Brotby and Gary Hinson. As you might suspect, *PRAGMATIC* is an acronym, reminding us that metrics should be Predictive, Relevant, Actionable, Genuine, Meaningful, Accurate, Timely, Independent, and Cheap. Dr. Hinson has done further work on the idea since then, and I'm very much looking forward to his next book on the topic.

The CoVID-19 pandemic has lessons to teach us about metrics. In British Columbia we get regular briefings and updates from Dr. Bonnie Henry, the provincial health officer, and Adrian Dix, the Minister of Health. Every statement starts with a standard list of metrics, and it is instructive to see what the different metrics actually mean.

The first numbers in every statement are the number of new cases, and the total number since the pandemic began. While these metrics are obviously important, right away we realize that possibly more important than the number of new cases is the trend: is the number of new cases more or less than it was the previous day, and for some days past. In other words, is the situation getting better, or worse? A recent addition to the statements is the number of the new cases that have not been confirmed through actual testing, but are, in the words of the reports, "epi-linked": people who have been found by contact tracing and epidemiological study to be infected.

One metric missing at this point is the total number of tests that have been done over the past day. In relation to the number of new cases, this gives us the positivity rate for the testing. The positivity rate can indicate a number of interesting things, although you have to be mindful to examine the situation carefully. If the positivity rate is too low, it may mean that you are testing the wrong people and wasting resources. However, if the positivity rate gets too high (and this generally means more than single digits) it likely means that you are not doing enough testing, and you are probably missing people who, especially with a disease like CoVID-19 which may generate a number of those infected who don't show any symptoms, can be out spreading the virus.

The total number of cases is interesting, but equally important, and the next set of numbers to be given, are the numbers of cases who have completely recovered, and, therefore, the total number of people who are still considered to be "active" cases. This is followed by the number of people in hospital and in intensive care, which provides some idea of the drain and demands placed on the healthcare system.

The next set of numbers in the briefings is the total numbers in the five different health regions in the province. This reminds us, in security, that total numbers are all very well, but that some parts of our enterprise may be unequally affected, and we need to keep track of that fact. In addition, recently a separate category has been added to this part of the statement, noting people who are not from the province and arrived here already sick.

The next metric is the number of deaths that have occurred in the past day. At this point, I should note that my use of the word "case," when I am actually talking about people, is simply following standard medical reporting terminology, and not an attempt to hide the fact that each case is a sick person, and each death is a death. As Adrian Dix points out, every day when the report has a death to list, every single death means loss and grief for friends, relatives, and society as a whole. It is important to remember the actual implications of the metrics.

The final metric that is included with every statement reports outbreaks in care facilities, hospitals, and in the general community. In security terms, this is alerting us to vulnerabilities in the system. Seniors, in care facilities, are not necessarily more likely to contract the disease, but the impact and outcome tends to be much more serious. Outbreaks in hospitals are, of course, obviously serious in a number of ways, including the greater risk to the health professionals who work there and on whom we all rely. Outbreaks in the community are important relevant to the situation: a large house party means somebody (actually a large number of somebodies) has been foolish and we can't do anything about that, but contact tracing needs to follow up on it. An outbreak in a workplace may mean that

Continued on page 16



Shut Up and Take My Money!

By Branden R. Williams – ISSA Distinguished Fellow, North Texas Chapter

I spent about half of my career in information security doing consulting work or being on the vendor side of the house and the other half in a practitioner role. Even as a consultant, I was often times masquerading as a practitioner on behalf of my client. As I continue my current role as a practitioner, I'm surprised at how the vendor population chooses to work with the practitioners in the field.

So much so that I copied Andy Ellis's vendor auto responder and customized it for myself.

Since this issue focuses on the business side of security, let's explore this relationship between buyer and seller in the information security space and talk about how to make it better. Ultimately, the audience of this column is much more the vendors vs. the practitioners.

The RSA Conference was the last event I did this year before we learned what Zoom Bombing was. Even with COVID-19, the floor was filled with vendors. Hundreds of booths, all with varying levels of matching features to needs in varying levels of completeness. It's nearly impossible to understand the entire vendor landscape. Even research firms like Gartner and Forrester will pick groups of folks to cover a specific slice of the industry vs. the industry as a whole.

It's bad enough enduring the catcalls through the expo floor with a full conference badge around your neck, so you can imagine how bad a practitioner's inbox is when the cost to send that message is effectively $0. I know I only see about 10 percent of the cold emails in my inbox because I see the rest any time I need to open up my spam folder to see if something legitimate got stuck there.

I suppose that gives me a pretty solid sample size to go on.

Cold emails that focus on you and not me are pretty quickly discarded. If I can Buzzword Bingo before exiting the first paragraph and I can't understand what your product or service even does, I'm definitely out. This usually comes from firms that reward quantity over quality, so sometimes we might even jump to unfair conclusions about your product quality based on your cold email.

If I can Buzzword Bingo before exiting the first paragraph… I'm definitely out.

When you have hundreds of vendors calling and emailing every quarter, you get pretty good at tuning the noise out. In fact, it's pretty rare for me to respond to one of those in a positive way at all. But when a vendor actually does the homework and approaches me with a way to solve a relevant and pressing business problem that I actually face in my job, I jump on it.

If a vendor focuses on quality in that cold email, there is a much higher likelihood I will engage. It's the difference in the lead-generation folks sending fifty emails per day versus five. A high quality email that fits in my world view is more likely to get my attention because I don't have to do the work for the vendor—it's done for me already.

Here's a prime example. I recently received an email for a security product, which I won't name to protect the innocent. It was a competitor to an existing product in place today that works quite well, something a quick Google search will confirm. The generic form email was something like "Hey my name is Hannah from XYZ company. I know you are busy, but I'd like to get an hour of your time to talk about our great product!" To be fair, it was a bit longer than that, but you get the point.

There was nothing in that email that helped me understand what business problem Hannah's product solved, or how I could do more with less, or even recognizing that there was a competing product in play. Emails like that obviously work otherwise Hannah's company wouldn't send them. But I couldn't fire off my auto responder fast enough.

For vendors looking to improve their game, consider reading through *The B2B Elements of Value* by Eric Almquist, Jamie Cleghorn, and Lori Sherer, published by the Harvard Business Review. In it the authors outline forty distinct kinds of value that a product or service could offer back to a business. If you cannot check off a vast majority of those, you are sunk. You need to be able to articulate how your product or service matches up to these value items. Invest in me and I'll invest in you.

Get me to a place where I say "Shut up and take my money!"

About the Author

Branden R. Williams, DBA, CISSP, CISM, is a seasoned infosec and payments executive, ISSA Distinguished Fellow, and regularly assists top global firms with their information security and technology initiatives. Read his blog, buy his books, or reach him directly at http://www.brandenwilliams.com/.

News That You Can Use…

Compiled by Kris Tanaka — ISSA member, Portland Chapter

October is National Cybersecurity Awareness Month

https://www.securitymagazine.com/articles/93518-october-is-national-cybersecurity-awareness-month

Are you ready to "Do Your Part and Be Cyber Smart?" Of course, you are. As we all know, October is a security professional's time to shine. This year's National Cybersecurity Awareness Month theme was designed to encourage individuals and organizations to own their role in protecting their part of cyberspace, stressing personal accountability and the importance of taking proactive steps to enhance cybersecurity. How are you helping to improve security awareness in your organization this month?

A Guide to the NIST Cybersecurity Framework

https://www.darkreading.com/physical-security/a-guide-to-the-nist-cybersecurity-framework/d/d-id/1339047

What should be in your cyber toolkit when you are building a risk management strategy? The National Institute of Standards and Technology (NIST) Cybersecurity Framework. Created and ratified by the United States Congress in 2014, the framework is used by over 30 percent of US organizations and it is one of the main ways in which businesses measure their preparedness in managing cyber-related security risks.

Businesses Are Trying to Remain Afloat, but Continue to Invest in Cybersecurity

https://securitybrief.eu/story/businesses-are-trying-to-remain-afloat-but-continue-to-invest-in-cybersecurity

Everywhere you look, companies are doing their best to tighten their belts and do more with less. Except when it comes to cybersecurity. According to a recent survey, overall IT budgets continue to fall, but the portion allotted to security is actually increasing year-over-year.

All Four of the World's Largest Shipping Companies Have Now Been Hit by Cyber Attacks

https://www.zdnet.com/article/all-four-of-the-worlds-largest-shipping-companies-have-now-been-hit-by-cyber-attacks/

Arr! Maybe it's time for the maritime industry to start brushing up on their cyber pirate talk. After last month's attack on French shipping giant CMA CGM, the industry received the dubious honor of being the only sector where all Big Four companies have suffered major cyber attacks, one after the other. Although ship hacking incidents tend to get more attention, experts say it is a company's shore-based systems that are more vulnerable these days, especially when it comes to attacks on their container booking applications.

The Cyber-Avengers Protecting Hospitals from Ransomware

https://www.wired.com/story/cyber-avengers-protecting-hospitals-ransomware/

Why do some security professionals do what they do? It's simple. They want to help and to do the right thing. Like the author said at the end, "When your mission is prevention, there's not much to show for a job well done. But when the world looks the way it does right now, the absence of one more bad thing feels almost tangible."

How Tabletop Exercises and Cyber Threats Have Changed Since COVID-19

https://www.cpomagazine.com/cyber-security/how-tabletop-exercises-and-cyber-threats-have-changed-since-covid-19/

Although COVID-19 may have impacted how security professionals are preparing for cyber incidents, one thing has remained constant. You need to conduct the drills and exercises with the right people in the room. Teams should include corporate counsel, HR, IT, public relations, and customer-facing departments such as account directors or call centers. Security no longer belongs to just IT. Everyone is responsible for keeping everything secure.

Does Your Board Really Understand Your Cyber Risks?

https://hbr.org/2020/09/does-your-board-really-understand-your-cyber-risks

It's all about the data. As company executives depend on various metrics to make the right decisions regarding cyber risk, they also depend on their security leaders and teams to help them translate the information into actionable data.

Every Day Is Cybersecurity Awareness Month

https://securityboulevard.com/2020/09/every-day-is-cyber-security-awareness-month/

Yes, it is Cybersecurity Awareness Month, but we all know that cybersecurity never ends. It is not a "one and done" mind-set. Security in the News would like to know what creative ideas you are implementing in your quest to fight cybercriminals. What things are you doing to keep your organization, family, and friends safe and secure? Share your strategies with Editor Thom Barrie.

ISSA
EDUCATION FOUNDATION

News from the Foundation

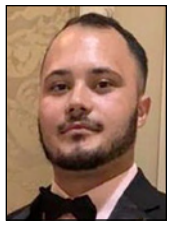
This Year's ISSA Local Chapter Scholarship Recipients

In addition to ISSAEF's three scholarships, the scholarship committee administers scholarships offered by ISSA's local chapters in Georgia and Texas. The Foundation's board of directors is pleased to announce the 2020 scholarship recipients.

Metro Atlanta ISSA Chapter scholarships



Frieda (Wilson) Chrysler (Gwinnett Technical College, Lawrenceville, Georgia) received the $1,000 Gwinnett Technical College scholarship. Frieda said *"I am beyond grateful to be awarded this scholarship by the ISSA Education Foundation. This award will not only help to pay my tuition and allow me to focus more on my academics but will serve as motivation in the continued pursuit of my degree and in cybersecurity."*



The $1,000 Kennesaw State University scholarship winner this year is **Jacob "Jake" Bulim**, who is currently enrolled in the Master's Program in Information Security and Assurance at the Kennesaw State University, Kennesaw, Georgia. He said *"I am honored to be awarded this scholarship from such an amazing organization and proud to be able to represent Kennesaw State University's prestigious information security programs."*

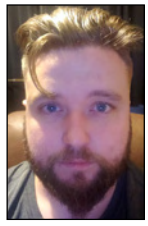


The $1,000 Georgia State University Scholarship was awarded to **Abhishek Soni**, studying towards his Master's in Information Security at Georgia State University, Atlanta, Georgia. Abhishek said upon receiving his scholarship *"By awarding me the ISSAEF scholarship, you allow me to focus on the most crucial aspect of school, learning. I hope that one day I will also help a student achieve his or her goals as you've helped me."*

Alamo ISSA Chapter scholarships



Hope Vernon (Western Governors University, Salt Lake City, Utah) received the $1,500 George "Chip" Meadows Memorial Scholarship from the ISSA Alamo Chapter. Upon receiving the award Hope stated *"Receiving this scholarship is not just about getting free money; it's giving me the opportunity to show the world all I have to offer as a woman in IT."*



The ISSA Alamo Chapter's $500 scholarship winner this year is **Corey Stroup**, St. Phillips College, San Antonio, TX. In commenting on the occasion, Corey said *"Being awarded this scholarship will no doubt prove to be a significant aid in my pursuit of my associate's degree and lessen the financial burden of my classes/certification exams."*

The Board thanks its scholarship committee, headed by Lorraine Frost, for all the effort vetting and selecting this year's recipients: Greg Gomel, Vincent Lam, Anna Carlin, Dmitry Zhdanov, and Rodolfo Rios.

Support the scholarship fund

We welcome your support and know our scholarship awardees do also. All donations are appreciated and much needed. You can donate via PayPal, by check, or online. ISSAEF is a 501(c)3 public charity, so you can make an individual tax-deductible donation to our scholarship program through our website https://www.issaef.org/donate, where you can also read about the various scholarship programs and past awardees. Thank you in advance for your generosity!

Support us while shopping

Help spread the word about these great opportunities to your friends and family at no cost to you—just use Amazon Smile while shopping online and automatically and with absolutely no cost to shoppers, a 0.5 percent of eligible purchases will be donated by Amazon to our scholarship fund! It's simple: start the purchase on https://smile.amazon.com, select "ISSA Education and Research Foundation Inc." (needs to be done only the first time), and shop as usual. Do not forget to tell your family/friends to do the same.

Take advantage of this time

Since many of us are in Covid-19 safer home mode, do you have a little extra time? Think of those traffic-jammed commutes that you haven't had to endure. So, instead of watching 19 reruns of the series *Friends* on TV, how about donating a few hours to help us help students who will become your successor so that you can get that next promotion in your career?

We are seeking volunteers to participate in short-term projects, scholarship publicity, fundraising, and governance of the Foundation. Those interested in joining a truly dedicated and enthusiastic group, please send an email with your background to volunteer@issaef.org.

Like us on Facebook and LinkedIn.

MASTERING YOUR FUTURE IN CYBERSECURITY

For many IT and security professionals, the view of the "security threat landscape" must look downright frightening. For starters, the prevalence of unprotected endpoints, phishing emails, and connected Internet of Things (IoT) devices is growing. Workers can share critical data using off-the-shelf collaboration apps, unsecured mobile devices, and public wi-fi networks. Complicating matters even further is the growing variety, volume, and complexity of cyber threats.

3.5 MILLION
NUMBER OF UNFILLED CYBERSECURITY JOBS BY 2021

But while there are many approaches to mitigating security risks, there's a shortage of professionals with the right skills to undertake the effort. Cybersecurity Ventures estimates there will be 3.5 million unfilled cybersecurity jobs by 2021, up from 1 million openings last year.

For organizations, this scarcity of security expertise could represent an invitation for serious breaches and potential liabilities. But for IT and security leaders, managers, and young professionals, today's evolving threat landscape also creates a prime opportunity for career advancement.

A SHORTAGE OF SECURITY TALENT

According to an ESG study, 53% of survey respondents reported a problematic shortage of cybersecurity skills at their organization, and it's only getting worse each year. Retaining and hiring enough skilled workers has become such a concern that it's taking away from more strategic priorities, according to 18% of respondents in IDG's 2019 Security Priorities Study.

One explanation for this talent shortage is that the rise, sophistication, and variety of security threats today require a new breed of professional. Forget about simply monitoring traffic and responding to attacks. Today's IT and business leaders must possess a unique blend of technical expertise and an understanding of how to manage cybersecurity operations, align cybersecurity programs with business priorities, and develop risk mitigation strategies that consider current laws and policies.

It's a tall order for talent. But security specialization can open doors to a wide array of career opportunities, not to mention highly competitive salaries, signing bonuses, and even enticing vacation packages.

THE VALUE OF ADDED CYBER EXPERTISE

The ever-evolving threat landscape and changes in user behavior and IT infrastructure require IT professionals to keep their knowledge up to date and stay on top of the latest trends and developments. Earning an online Master of Information Technology with a specialization in cybersecurity or one of three online graduate certificates in cybersecurity topics from Virginia Tech can help individuals meet these heightened demands in a number of ways:

A LAUDED APPROACH TO SPECIALIZED GRADUATE EDUCATION

Ranked the #4 online graduate IT program by *U.S. News and World Report*, Virginia Tech's VT-MIT program takes a unique approach to specialized education. Core courses in areas such as information systems design, electronic commerce, software engineering, and computer programming help students master technical expertise in a business context. After completing these core courses, degree students can choose to specialize in cybersecurity. Areas of focus range from cybersecurity management – for those interested in running their own in-house cybersecurity practice – to cybersecurity policy, which explores the legal and ethical concerns triggered by data breaches. This breadth of content allows students to tailor their education around their career ambitions.

RICH, REAL-LIFE RESOURCES FOR LEARNING

Part of Virginia Tech's core strength is its world-class cybersecurity research, supported by $15 million in research grants and contracts. Students can access six cybersecurity research centers, including the Hume Center for National Security and Technology. Another invaluable resource: Virginia Tech's highly experienced faculty, the majority of which are tenured or on the tenure-track, and who are known for their research in information, hardware, and software security.

CAREER NETWORKING OPPORTUNITIES

Although the VT-MIT program is online, there are plenty of advantages to earning a degree from a program based in the Washington, D.C., area, a region with high demand for cybersecurity expertise. Access to capital, a highly educated workforce, strong economic growth, and a stable business climate define the state of Virginia, and neighboring Maryland and Washington, D.C. For Virginia Tech students, this translates into a vast network of industry professionals, students, alumni, and mentors, many of whom can connect students with opportunities for career advancement. Adding to Virginia Tech's cyber portfolio is its designation as a National Security Agency Center for Academic Excellence in Cyber Operations.

A VIBRANT STUDENT BODY

The VT-MIT program's online delivery format allows students to pursue higher education at their own pace – a flexibility that attracts a range of working professionals. Further enriching the student environment is the program's openness to students with diverse backgrounds and interests, including business line leaders looking to improve their technology capabilities while leveraging their domain expertise.

A BRIGHT FUTURE

Combating today's cyber threats has never been more difficult, nor more critical to business continuity. A Master of Information Technology degree with a specialization in cybersecurity from Virginia Tech can help leaders better understand the systemic nature of these threats, and teach them strategies for dealing with an increasingly complex security landscape. Indeed, as demand for security expertise grow, so too do the job opportunities for Virginia Tech graduates.

Learn more about Virginia Tech's 100% online Master's degree and graduate certificate options with cybersecurity specializations at vtmit.vt.edu.

MASTER OF INFORMATION TECHNOLOGY
VIRGINIA TECH

Using PCI Scope to Lower Risks and Cost

By R. Scott Pierangelo and David Lam

This article discusses leveraging technology identified in PCI Self-Assessment Questionnaires A and P2PE to reduce the risks and costs to an organization when processing credit cards, which also subjects the organization to fewer and less onerous compliance requirements. By leveraging newer technology and risk transfer, organizations can in some cases reduce questions almost tenfold.

If you process credit cards as part of doing business, you must comply with the Payment Card Industry Data Security Standard (PCI DSS). This can be a very onerous process. However, you have options to reduce your scope by leveraging new technology. This article serves to highlight those options and give some background on the PCI-compliance process.

What is PCI compliance?

The PCI DSS is an information security standard that organizations must be compliant if they store, process, and/or transmit credit card data [6]. The standard is maintained by the PCI Council, which is comprised of the major credit card brands (America Express, Visa, Mastercard, Discover, and JCB). Based on the volume of credit cards stored, processed, and/or transmitted by an organization, an organization can be a level 4, level 3, level 2, or level 1 merchant and/or service provider (with level 1 being the highest volume). If an organization is a level 1, it must complete a level 1 assessment and a third-party qualified security assessor (QSA) must perform the assessment. For all other levels, a self-assessment questionnaire (SAQ) can be completed; QSA assistance is optional, although it is recommended.

Finding the scope

The first and most critical part of PCI compliance is finding the right scope when answering your self-assessment questionnaire. According to the PCI Security Standards Council, "The PCI DSS self-assessment questionnaires (SAQs) are validation tools intended to assist merchants and service providers in self-evaluating their compliance with the PCI DSS" [5]. Note that many large businesses do not qualify to fill out the self-assessment questionnaires, but an enormous amount of businesses do.

Scope includes systems that process, store, or transmit cardholder data or provide security services for said data and the systems the data traverses. Networks that are not segregated properly can also be in scope. For many small and medium businesses (SMBs) this means bringing into scope systems that aren't properly secured in accordance with the requirements. In a nutshell, reducing scope includes both having less systems that might handle cardholder data and not having any cardholder data to touch or store.

Interestingly enough, most businesses are not well versed in what questionnaire needs to be filled out. In fact, both of the authors have worked on situations where clients were answering over two hundred unnecessary questions and becoming compliant to those standards because the organization and their teams were not appropriately educated in what questionnaire to fill out when achieving compliance. Here are two things to consider:

- Different SAQ questionnaires meet different PCI needs.
- The number of questions range from 22 to 329 (unless you are a service provider). This means that the choices you make in implementing credit card acquisition has a significant impact on your business, both from a cost and a workflow perspective.

Now, here are the magic words. The self-assessment questionnaires that you want to look for when you are reducing scope are A and P2PE [2]:

- SAQ-A allows your organization to reduce your questions down to 22 for web transactions simply by never seeing a credit card number or having it pass through your website.
- SAQ-P2PE is a newer level of self-assessment questionnaire that allows merchants to reduce the scope of their questions by using certified point-to-point encryption solutions so that the merchant is never able to see credit card information. A number of payment processors are still in the dark regarding P2PE, and quite a few are still in the process of getting certified. We will talk more about this below.

Note that these questionnaires won't apply to you if you are doing custom, advanced solutions like major retailers, such as Home Depot or Target, but if you are in the midmarket or below, these questionnaires are gifts.

When it comes to determining the correct approach for your PCI-DSS assessment, ensuring your scope is accurate is of the utmost importance. If the scope of the assessment is not performed correctly/accurately, you could find yourself doing more work than is needed, or worse, not truly being compliant with your chosen SAQ.

Self-assessment options

The following are the various SAQ options allowed by the PCI Council:

SAQ Type

A (22 questions)

Card-not-present merchants (e-commerce or mail/telephone order) that have fully outsourced all cardholder data functions to PCI DSS-compliant third-party service providers, with no electronic storage, processing, or transmission of any cardholder data on the merchant's systems or premises. Not applicable to face-to-face channels.

A-EP (191 questions)

E-commerce merchants who outsource all payment processing to PCI DSS-validated third parties and who have a website(s) that doesn't directly receive cardholder data but that can impact the security of the payment transaction. No electronic storage, processing, or transmission of any cardholder data on the merchant's systems or premises. *Applicable only to e-commerce channels.*

B (41 questions)

Merchants using only imprint machines with no electronic cardholder data storage and/or standalone, dial-out terminals with no electronic cardholder data storage. *Not applicable to e-commerce channels.*

ISSA
Information Systems Security Association International
www.issa.org

Members Join ISSA to:
- Earn CPEs through Conferences and Education
- Network with Industry Leaders
- Advance their Careers
- Attend Chapter Events to Meet Local Colleagues
- Become part of Special Interest Groups (SIGs) that focus on particular topics

Join Today: www.issa.org/join
Regular Membership **$95***
(+Chapter Dues: $0-$35)*
CISO Executive Membership **$995**
(Includes Quarterly Forums)
**US Dollars/Year*

B-IP (82 questions)

Merchants using only standalone, PTS-approved payment terminals with an IP connection to the payment processor, with no electronic cardholder data storage. *Not applicable to e-commerce channels.*

C-VT (79 questions)

Merchants who manually enter a single transaction at a time via a keyboard into an Internet-based virtual terminal solution that is provided and hosted by a PCI DSS-validated third-party service provider. No electronic cardholder data storage. *Not applicable to e-commerce channels.*

C (160 questions)

Merchants with payment application systems connected to the Internet, no electronic cardholder data storage. *Not applicable to e-commerce channels.*

P2PE (33 questions)

Merchants using only hardware payment terminals that are included in and managed via a validated, PCI SSC-listed P2PE solution, with no electronic cardholder data storage. *Not applicable to e-commerce channels.*

D (329 questions)

For merchants: All merchants not included in descriptions for the above types.

D (370 questions)

For service providers: All service providers defined by a payment card brand as eligible to complete a self-assessment questionnaire.

As you can see, there are a lot of options, and it is crucial to select the correct one [1].

Effect of scope reduction

The net effect of scope reduction is dramatic. For example, if you are filling in a SAQ-P2PE with 33 total questions, most of these are around training, procedures, and documentation. In actuality, with a P2PE questionnaire you only have a limited number of pure security requirements, which are typically trivial for organizations with any level of information security management system. The biggest requirement to consider is the management and tracking of all P2PE hardware devices. A formal secure courier process, along with updating/maintaining a full inventory of each device, will be some of the most important things to implement for the P2PE. However, some P2PE vendors will provide assistance with these requirements, so when shopping around you should inquire if they do.

The same holds true for the SAQ-A. At only 22 questions, it is the simplest and easiest of all the questionnaires. The biggest thing to ensure here is that the outsourcing of all storage, processing, and payment of card data for your e-commerce is done through a PCI-validated third party. While independent validation should be done, when shopping around you should ask any vendor if their solution will qualify you for an SAQ-A.

One important note to mention about SAQs. If you have multiple payment channels (i.e., e-commerce, face-to-face in stores, etc.) you can complete an SAQ for each channel and not have to include them all in the same scope under one SAQ. As an example, if you have brick and mortar stores with P2PE devices only, and a website outsourced to a third party compliant with PCI, you can fill out and SAQ-A and SAQ-P2PE.

Selecting the right vendor

The first big issue facing companies is determining how their "PCI approved" vendors fit into these SAQs. It's very important to know that many companies that represent themselves as PCI-compliant vendors are not really telling you much about how exactly they are compliant. We've encountered multiple organizations saying they were PCI compliant, meaning compliant in the way they take credit cards, as a merchant, and that had absolutely nothing to do with being compliant as a service provider and helping you, as an organization, meet the PCI guidelines.

Scoping works both ways

Remember, since PCI allows you to scope, the scope of any implementation is critically important. We have seen companies hire a QSA to come in and perform an assessment, get their PCI-DSS report on compliance (RoC) and attestation of compliance (AoC), which certifies them as PCI compliant as a service provider and not just a merchant, as discussed in the previous paragraph. While it might seem on the surface that you as the customer have nothing to worry about, it is not that simple. There are two critical things to consider when assessing a PCI vendor/service provider: what's the scope of the PCI certification and who is responsible for what.

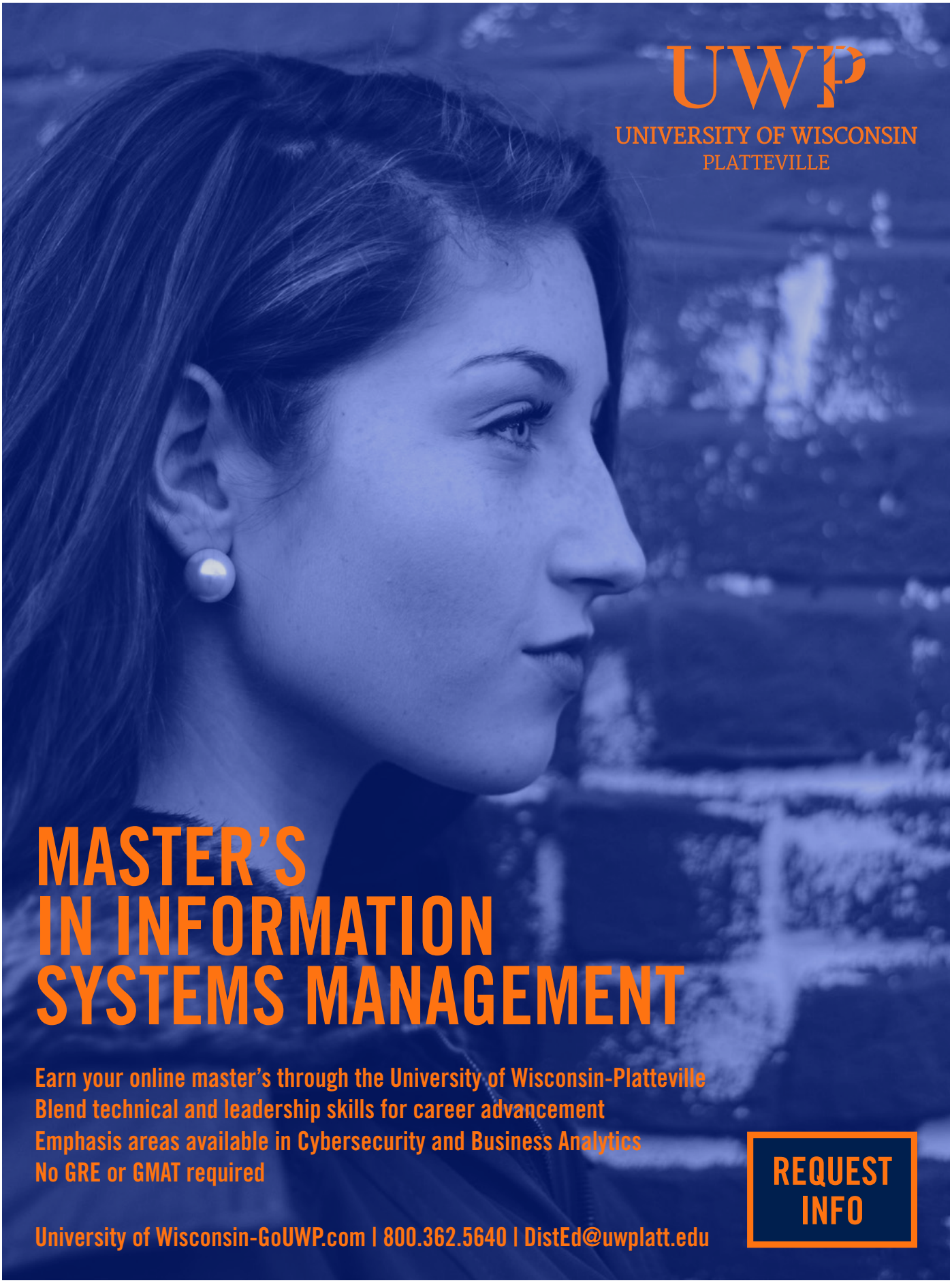
Responsibility matrix

As an example, let's say Acme Inc. has a managed intrusion detection service (IDS) that will potentially process packets that could contain encrypted cardholder data. Acme gets validated for PCI compliance. They can now say they are PCI compliant, except the scope of that assessment didn't cover the managed IDS system and its setup/compliance with PCI standards. You now use Acme Inc's IDS device, which is supposed to be PCI compliant and presume that your IDS responsibilities are now under the scope of Acme Inc's PCI responsibility. This is where the service provider *responsibility matrix* comes into play—essentially a document that should be provided by any PCI vendor that outlines question by question, control by control, what the vendor is claiming is your responsibility, what is theirs, and what is shared.

Vendor selection criteria

It's important that you be aware of the critical PCI-compliance elements to find out about your vendors. Please note that:

- The vendor you choose makes a difference. For example, one company chose a PCI-compliant vendor that could


UWP
UNIVERSITY OF WISCONSIN
PLATTEVILLE
MASTER'S
IN INFORMATION
SYSTEMS MANAGEMENT
Earn your online master's through the University of Wisconsin-Platteville
Blend technical and leadership skills for career advancement
Emphasis areas available in Cybersecurity and Business Analytics
No GRE or GMAT required
REQUEST
INFO
University of Wisconsin-GoUWP.com | 800.362.5640 | DistEd@uwplatt.edu

not provide a solution to meet the lower level SAQ-A questionnaire (22 questions). Instead the company would have needed to fill out a SAQ-A-EP (191 questions) and got a much longer, more stringent list of questions to answer and to which they were required to be compliant.

- Another company did not consider PCI compliance with regard to voice over IP phone systems. They now face a SAQ-D because their provider was not PCI certified. As a result, this organization had to fill out the most onerous of the self-assessment questionnaires to achieve compliance. We address this in greater detail in our case study section, below.

Case studies

Let's take a look at this from two different angles: taking credit cards in person or over the phone versus taking credit cards over the web. Keep in mind, that depending on the methodology you use, you can have to answer up to 329 questions. The goal is to significantly reduce this number *and* your risk exposure.

P2PE

In order to make it easier on merchants, in 2012 the PCI Council released the P2PE standard, which stands for point-to-point encryption [3]. When we work with companies to identify appropriate P2PE devices, we are often met with confusion on the part of payment processors because P2PE is seemingly not yet well understood. Interestingly enough, it is really very simple. If you acquire a P2PE device from a payment processor who is P2PE certified, you only have to fill out thirty-three (33) relatively easy questions to be compliant. And the process for taking credit cards is easy. You can dip the card if you have it physically present, or depending on the device, type the card number into the device. How hard is it to get it? You just have to ask the right vendor.

We've also found that from a cost perspective, these devices cost approximately the same as legacy systems. Interestingly, some companies have saved money by moving to a new provider. These savings come in many forms, and an especially big one is the reduction of in-scope systems that have to be included in the scope of an assessment each year. You can also save an enormous amount of time because when each year's PCI assessment rolls around, the amount of work, including evidence and screenshots, is greatly reduced.

>>Sidenote: Voice over IP: Plague or panacea

Of course, it wouldn't be a story without some drama. Here's the interesting potential caveat and a happy ending. In November 2018, the PCI Council distributed new guidance regarding usage of voice over IP (VOIP) to transit conversations that contain cardholder data [4]. The primary issue is that leveraging a voice over IP telephone system almost automatically gets you the full 329 questions of the SAQ-D because of the potential for compromising the data riding over a phone system. The good news is if your VOIP provider is PCI compliant, that's no longer a concern for you, and you can use the P2PE questionnaire with a limited scope. **Moral of this story:** be sure that nothing in your ecosystem ruins your ability to use a less onerous SAQ.

Note that the VoIP situation is complicated by having a call center, and that additional consideration needs to be applied should you record your calls. Dual-tone multi-frequency (DTMF) and automated speech recognition (ASR) are other options to keep cardholder data out of your VOIP scope. DTMF and ASR allow for routing credit card collection to a qualified and certified third-party provider, keeping that dangerous cardholder data off your network.

Web answers

Now, let's talk about the web. When you are designing a website and have to interface with a payment processor, you have a multitude of options. The PCI DSS is concerned about what access you might have to any credit card information when processing a credit card transaction. So, using an SAQ-A, the DSS gives you a couple of options by which you can bypass the maximum 329 questions of a D or the 191 questions of an A-EP (an option for some web implementations) by simply choosing an appropriate methodology and a vendor that supports it to lower your scope and get your number of questions down to the 22 relatively easy questions of an SAQ-A.

In the case of an SAQ-A, you either have to request the credit card via an i-frame (a way to embed access to another webpage in your webpage) or redirect to a website or code that is managed by your payment processor. And achieving this level of compliance is even easier than the P2PE model. You don't need to buy anything; you just need to make sure that the payment processor has a reasonable method by which you

Security, and Business, Metrics

Continued from page 7

health and safety needs to look at the environment and processes in order to issue orders to ensure that businesses and industries may continue to operate safely.

About the Author

Robert Slade has written a number of these columns, and the number of words in each is remarkably similar. His book on cybersecurity lessons that CoVID-19 is teaching us should be out soon, and he hopes a number of you will buy it. More metrics than anyone would want to know about him, and a number of links to bits from the book, are available at https://twitter.com/rslade. A number of people have tried to get him to take bio writing seriously; you can try too, at rslade@gmail.com.

can request a credit card number from your customer—that will get you an SAQ-A questionnaire.

Where to start?

You may want to work with an appropriate PCI expert to understand all the nuances and differences. For even a medium-size business, the difference in cost can be considerable for just the remediation alone. And, remember, the costs are not just what it takes to implement but also to *maintain* the system. Furthermore, even if you don't have direct access to cardholder data, you can still maintain your effective business workflow through your provider's software, including recurring payments.

As we all well know, IT vendors hold the keys to your kingdom. Depending on the nature of IT services you are purchasing, your risk can vary widely. For example, if you are using a vendor to do IT support, they likely have full administrative access to your system. That means they need to comply with all the laws, regulations, and contractual obligations that you have in place. Software vendors create software that you depend on, and it is virtually impossible to see what's going on under the hood. The situation is exacerbated if your software is hosted in a cloud solution, as that cloud provider typically has 100 percent access to your data all of the time. Additionally, you cannot forget about your phone system, which carries a significant amount of confidential information. The way a phone system is managed, from the handoff of a call from the traditional phone system to your VOIP phone on your desk, is critical to maintaining appropriate security.

Once you have researched a few vendors for your needs, there are some preliminary questions you should ask before proceeding:

- Are you PCI compliant? If so, what is your compliance date?
- What is the scope of your PCI compliance?
- Can you provide your attestation of compliance (AoC) for our review?
- Do you have a service provider responsibility matrix you provide to customers, outlining what responsibilities you cover, what we (the customer) need to cover, and what responsibilities are to be shared?
- If the merchant is a P2PE provider, have the device and software been specifically assessed against the PCI P2PE standard, and is it listed on the PCI website?

Conclusion

Vendor risk management is essential to appropriate information security hygiene. However, this goes to a completely different level when PCI is in the mix. If you process credit card transactions as part of your business, PCI compliance is a critical part of staying out of trouble both from the perspective of being able to take payments via credit card and from the possibility of significant fines and penalties should you have a breach or be audited.

In summary, the PCI Council gives you a number of excellent options for reducing your PCI scope and transferring responsibility to PCI compliant providers. By understanding your options, you can reduce cost and risk. Finally, always remember that YOU are responsible for maintaining the compliance of whatever the vendor does not explicitly claim responsibility for in writing. It is important to remember that one of the biggest reasons to use a vendor to process your credit cards is to outsource responsibility; if you are not getting that transfer of responsibility with your contract, you are not getting the most for your investment.

References

1. Mateaki, George. "PCI Standards: Which PCI SAQ Is Right for My Business?" Security Metrics – https://www.securitymetrics.com/blog/pci-standards-which-pci-saq-right-my-business#:~:text=Each%20SAQ%20includes%20a%20list,Requirements%20of%20PCI%20DSS%20Compliance%3F – an excellent blog post for a breakdown of SAQ requirements.
2. PCI SSC, "Completing Self Assessment," PCI Security Standards Council –https://www.pcisecuritystandards.org/pci_security/completing_self_assessment – for learning more about completing self-assessments.
3. PCI SSC, "P2PE Program," PCI Security Standards Council –https://www.pcisecuritystandards.org/pdfs/120627-P2PE-Program-Guide_SAQ_Update.pdf – P2PE announcement.
4. PCI SSC, "Protecting Telephone-Based Payment Card Data," PCI Security Standards Council – https://www.pcisecuritystandards.org/documents/Protecting_Telephone_Based_Payment_Card_Data_v3-0_nov_2018.pdf – information on configuring cardholder data transit over voice over IP.
5. PCI SSC, "SAQ Instructions," PCI Security Standards Council –https://www.pcisecuritystandards.org/documents/SAQ-InstrGuidelines-v3_2_1.pdf – page 3.
6. PCI SSC, "Why Security Matters," PCI Security Standards Council –https://www.pcisecuritystandards.org/pci_security/why_security_matters – an excellent discussion of the risks and impacts of a PCI-related breach.

About the Authors



R. Scott Pierangelo, MSCS, QSA, CISSP, CISA, CISM, CRISC, CGEIT, PMP, CDPSE, PCIP, is a founding partner of Silent Storm Security and has been conducting auditing assessments for over twelve years. He may be reached at spierangelo@silentstormsecurity.com.



David Lam, CISSP, CPP, is partner and CISO at Miller Kaplan. He has 33 years of IT experience in positions of increasing responsibility, 29 of which include information security. He may be reached at dlam@millerkaplan.com.

Cyber Risk Management: Strategic Plan or Afterthought?

By Mark Langford – ISSA member, North Texas Chapter

This article discusses the current state of cyber risk management and the emerging factors that will motivate organizations to invest sufficiently in their cyber defenses to protect their vital data assets.

Abstract

Discussions about managing cyber risk need to move from the break room to the board room in order to adequately evaluate cyber risk as another form of strategic business risk. Cyber threats are increasing in both frequency and complexity, yet a majority of organizations are still not investing in people, processes, tools, training, and cyber insurance to adequately defend themselves and mitigate their cyber risk to a level they themselves have defined as being acceptable. The fear of going out of business has not been enough to motivate all organizations to invest sufficiently in their cyber defenses… but other factors are emerging that will.

Current state of risk management

Cyber risk for all organizations continues to rise due to a variety of factors including the increasing value of data assets, the increased frequency and complexity of attacks, the inability of law enforcement to forge an effective deterrent, and the lack of legislative and commercial penalties in place to force executives to invest further in their cyber defenses. Despite the increase in successful cyber attacks, and despite their desire to mitigate cyber risk, most organizations are still not investing in people, processes, tools, training, and cyber insurance necessary to bring their cyber risk down to a level that they themselves have defined as being acceptable.

Last year, organizations were expected to spend roughly $3.7 trillion dollars on information technology [6]. Of this, between 3.7 and 10 percent of their IT budgets were spent on security [1]. Yet, based on a survey that Cybershark conducted of a mix of different sized companies across all verticals, organizations would need to spend between nine and 13 percent of their IT budget in order to achieve an acceptable level of cyber risk. In reality, businesses typically spend less than six percent of total IT budgets on security and risk management [5]. The difference between actual spending on security to reduce cyber risk and projected spending to achieve the desired level of cyber risk is shockingly large and begs the question, "if an organization knows it is at risk, and wants to reduce its cyber risk exposure, why is management not investing more in security?"

To try to answer this question, I conducted an informal poll of CIOs and CISOs primarily of small-to-medium-sized businesses. The answers I received were mixed and fell into these categories:

- I trust the defenses we have in place
- I don't think we're at risk
- We don't have the budget, so we have to accept any residual risk
- We know we've got a problem and we're trying to fix it
- We've got an MSP that does this for us
- We're too busy now trying to manage our way out of this pandemic
- We don't have anything anyone would want to steal

What I concluded from these answers is that, for most organizations, the perceived economic cost of a data breach has not been large enough to create a sense of urgency in the improvement of cyber defenses. I also inferred that there is a rising level of frustration among senior executives who are looking for a return on their increasing security investments over the past 10-15 years.

Yet, the total economic costs of a data breach can be staggering. Deloitte was commissioned recently to conduct a foren-

sic accounting of a data breach to a large healthcare services company and determined that the directly identifiable costs associated with the breach (remediation of the attack, customer notification, providing customers with credit monitoring services, HIPAA fines, public relations, and legal fees) over a five year period totaled more than $59M. Deloitte then calculated the hidden costs associated with the same breach over the same time period: the lost revenue, loss of customer referrals, brand damage, increased cost to borrow money, and increased costs for cyber insurance premiums and found that these hidden costs exceeded $1.7B…more than 27 times as much as the directly identifiable costs [8].

If the economic costs of a data breach are to be avoided; if 60 percent of SMBs fail within six months of a cyber attack [10]; and if the fear of going out of business is not enough by itself to motivate organizations to adequately invest in their own cyber defenses, then what will? The following factors are all, to some extent, going to contribute to improvements in cyber defenses.

Legislation

Some federal legislation has been passed to protect information in specific industries: HIPAA (1996) and HITECH (2009) in the health care industry, the Gramm-Leach-Bliley Act (GLBA) in 1999 to protect financial information, and the 2002 Homeland Security Act, which included the Federal Information Security Management Act (FISMA), to improve security measures among federal agencies. Unfortunately, when it comes to consumer privacy, even though the Federal Trade Commission (FTC) has the power and broad authority to enforce data protection regulations in the United States, there is no federal data privacy law or central data protection authority tasked with ensuring compliance. Instead, the responsibility to pass and enforce data privacy legislation is left up to the individual states. Current security legislation at the state level is primarily focused on privacy of personal data, with the strongest legislation, the California Consumer Privacy Act (CCPA) of 2019 being the closest any state in the US has come to emulating the General Data Protection Regulation of 2018 that governs consumer privacy in the European Union. Two other states, Nevada and Maine, have also enacted comprehensive privacy laws with Maryland, Massachusetts, Rhode Island, and others expected to follow shortly. Yet, as of July 2, 2020, only 25 states have passed any type of data privacy laws, and only 35 states and Puerto Rico have passed their own data disposal laws. Fortunately, all 50 states have now passed data breach notification laws [4].

The lack of federal cyber security legislation may change after the November elections. Senator Elizabeth Warren of Massachusetts proposed an amendment in April 2019 that would establish criminal liability for negligent executive officers of major corporations. Her proposed *Corporate Executive Accountability Act* would enable regulators to fine and even imprison executives who turned a blind eye to scams or were otherwise negligent with the company's assets [14].

It's important to note here that federal, state, and local law enforcement are currently only able to achieve an effective enforcement rate of 0.05 percent of cybercrimes. The cybercrime wave is so big it should be setting off alarm bells at every level of law enforcement. And yet, the response from the enforcement community is a drop in the bucket compared to the sheer volume of crimes occurring [7].

This issue is compounded by the fact that no one has been charged with negligence in even the most egregious data breaches in US history (Equifax, Marriott, Facebook, Yahoo, etc.). There is a substantial need to revamp both the enforcement of cybercrimes and the prevention of corporate negligence. Until both improve, cyber criminals will continue to operate with impunity, and upgrades to cyber defenses will be given a lower priority by organization executives.

Key customer and peer demands

In the absence of strong cybersecurity legislation, organizations are stepping up to protect themselves by conducting risk attestations, essentially a security process review with their key suppliers and partners to ensure a transparent level of understanding about how both organizations are securing their vital data. Security attestations are usually tedious comparative exercises if the two companies do not already subscribe to the same risk framework (NIST, ISO, CIS, etc.) and should not be considered a replacement for SOC 1 or SOC 2 (although there is some overlap) [2].

The fact that organizations feel motivated to perform these time-consuming risk policy and procedure comparisons is both a tribute to their desire to move ahead and conduct business safely with peers, key customers, and key suppliers as well as an indictment of the lack of a standard third-party process for all to adopt and adhere.

ISSA JOURNAL
Infosec Book Reviews

Have you read an excellent information security book of value to ISSA members? You are invited to share your thoughts in the ISSA Journal.

- Summarize contents
- Evaluate interesting or useful information
- Describe the value to infosec professionals
- Address any criticisms, omissions, or areas that need further development

Review should be 500-800 words, including short bio, photo, and contact email. Submit your review to editor@issa.org.

ISSA Information Systems Security Association
DEVELOPING AND CONNECTING CYBERSECURITY LEADERS GLOBALLY

Competition

According to the recent *Forbes Magazine* article, "Using Cyber Security as a Competitive Advantage," there are three areas in which companies are now realizing they can use investments in cyber security defenses as a competitive advantage: productivity, public relations, and gaining/retaining employees [9].

Many small-business owners view cybersecurity as "nice to have" rather than a "must have" and therefore don't treat it as a form of business continuity. This creates an advantage for a more prepared competitor when it comes to maintaining productivity over the long term, assuming all competitors are equally likely to be the focus of a cyber attack. By making modest investments in fail-safes, like image-based backups, an organization can mitigate cyber risk and increase the likelihood of business continuity and productivity.

The lack of a cybersecurity policy framework or documented procedures can also become a PR nightmare. By instead proving to your customers, your employees, and your business partners that you are responsibly performing due care and due diligence of a security policy, you are showcasing to everyone how seriously you take the security of their data as well as your own. Like the fable of the "Three Little Pigs," [11] you'll be waiting in your house made of bricks to take in any clients fleeing from houses less defended.

Taking steps to protect vital intellectual property that your staff have developed not only secures their pride of achievement and contribution, but also their willingness to continue to do so. By compartmenting access to vital data assets, you limit the extent of data that could be lost by an employee going to work for a competitor and taking hard-earned intellectual property when leaving the company.

Commercial pressures

While there are some commercial data security agreements in place that have motivated participating organizations to improve and standardize their data protection procedures, like PCI DSS in the credit card industry, there are other types of commercial motivations that are emerging that will stimulate board-level thinking and investment in cyber defense improvements. One example involves mergers and acquisitions. Increasingly, M&A brokers are including cyber risk assessments in their overall business valuations since, after all, the attractiveness of a company can be greatly impacted by its ability to avoid a costly data breach [13].

A second commercial motivation for cyber defense improvements is emerging from credit rating agencies like Moody's. Similar to M&A brokers, Moody's has announced that they are incorporating cyber risk assessments into their valuations, so companies wanting to maintain their preferred rating must now prove that they are performing information security due care and due diligence [12].

Conclusion

Discussions about managing cyber risk can and should be held at the most senior levels within any organization and should be treated like other forms of strategic business risk. While most organizations continue to invest in their cyber defenses at a level that is inadequate to achieve what even they define to be acceptable risk, there are some signs of hope that you can have your cake and eat it too by investing in low-cost/high impact areas like employee awareness training to prevent an attack from occurring in the first place, or by more frequent archiving and data compartmentalization.

Escalations to the board room of what constitutes appropriate cyber defense strategy and investment level will be influenced greatly by two growing realizations: intellectual property and network continuity are valuable and worth protecting, and the economic costs of a data breach—not only the direct costs to remediate the damage, but also the much larger hidden costs related to lost sales, reduced volume of referrals, and damage to brand—are much larger than the cost of preven-

ISSA
CYBER EXECUTIVE FORUM



October Virtual Cyber Executive Forum 2020

October 23 @ 9:45 am - 5:30 pm EDT (US)

5 Sessions • 2 Roundtables • Lunch

National 9-1-1: Becoming Public's Safety Achilles Heel

Security Leaders Must Be Part of the Sales Team

Molding Your Cyber Workforce: Don't Rely on the Punditry

USG efforts to "Deliver Uncompromised": DoD CMMC, NIST SP 800-171 and the new FASC

Things to Consider before Adopting Zero Trust

Questions? Please contact Guy Wiltse: +1 (703) 382-8205 (local/international) or guy.wiltse@issa.org.

CLICK HERE TO REGISTER

tive cyber defense measures and can easily mean the difference between organizational survival and failure.

Finally, for those senior executives who are discouraged by the lack of tangible progress in mitigating cyber risk (and therefore in justifying previous investments in cyber defenses) and who are contemplating reducing the rate of their security investments, Gartner suggests the following [3]:

- Drive cybersecurity priorities and investments by using an outcome-driven approach that balances investment and risk with the need to achieve desired business outcomes.
- Improve cybersecurity readiness by treating it as a choice and a business decision.
- Build a business case and executive narrative to change how cybersecurity is treated in the organization.

Substantial improvements in mitigating cyber risk can be obtained with modest investments in time and money. Cyber awareness training for all employees and frequent data archiving are two examples of low-cost/high-impact activities that every organization should conduct that may actually reduce investments in security while improving cyber defenses.

The amount of attention and board room discussion concerning the development of an effective cyber defense strategy will increase over time, but it may not be in time for some.

References

1. Asen, Alex, et al. "Are You Spending Enough on Cybersecurity?," BCG, February 20, 2019 – https://www.bcg.com/en-ca/publications/2019/are-you-spending-enough-cybersecurity.
2. AuditBoard, "Cybersecurity Attestation What You Should Know," AuditBoard – www.auditboard.com/blog/what-you-should-know-about-cybersecurity-attestation/.
3. BitSight Technologies, "The Urgency to Treat Cybersecurity as a Business Decision," BitSight Technologies – https://info.bitsight.com/the-urgency-to-treat-cybersecurity-as-a-business-decision-ppc?&utm_term=cybersecurity&utm_matchtype=p&utm_campaign=NA+|+ToF+|+-Cybersecurity&utm_source=adwords&utm_medium=cpc&utm_adgroup=NA+|+ToF+|+Cybersecurity&utm_content=Gartne.
4. Brooks, Ryan, "US Privacy Laws: State-Level Approaches to Privacy Protection," Netwrix – https://blog.netwrix.com/2019/08/27/data-privacy-laws-by-state-the-u-s-approach-to-privacy-protection/#:~:text=All percent2050 percent20U.S. percent20states percent20have percent20data percent20breach percent20notification percent20laws percent2C percent20at,their percent20own percent20data percent20privacy percent20laws.
5. Carfagno, Don, "How Much Should Your Company Invest in Cybersecurity?" Cybershark, November 4t, 2018 – https://www.blackstratus.com/how-much-should-your-company-invest-in-cybersecurity/.
6. Costello, Katie and Rimol, Meghan, "Gartner Says Global IT Spending to Grow 3.7 percent in 2020," Gartner, October 23, 2019 – https://www.gartner.com/en/newsroom/press-releases/2019-10-23-gartner-says-global-it-spending-to-grow-3point7-percent-in-2020#:~:text=Worldwide percent20IT percent20spending percent20is percent20projected,latest percent20forecast percent20by percent20Gartner percent2C percent20Inc .
7. Eoyang, Mieke, et al. "To Catch a Hacker: Toward a Comprehensive Strategy to Identify, Pursue, and Punish Malicious Cyber Actors," Third Way – https://www.thirdway.org/report/to-catch-a-hacker-toward-a-comprehensive-strategy-to-identify-pursue-and-punish-malicious-cyber-actors#:~:text=The percent20FBI percent20IC3 percent20report percent20for percent202016 percent20notes percent20298 percent2C728 percent20complaints percent20received percent20that percent20year.&text=Based percent20on.
8. Fancher, J. Donald, et al. "Beneath the Surface of a Cyber Attack : A Deeper Look at Business Impacts," Deloitte – https://www2.deloitte.com/us/en/pages/risk/articles/hidden-business-impact-of-cyberattack.html.
9. Foret, Will, "Using Cyber Security As a Competitive Advantage," Forbes Business Council – https://www.forbes.com/sites/forbesbusinesscouncil/2019/10/09/using-cyber-security-as-a-competitive-advantage/#5985e97d7ff7.
10. Galvin, Joe, "60 Percent of Small Businesses Fold Within 6 Months of a Cyber Attack," INC – https://www.inc.com/joe-galvin/60-percent-of-small-businesses-fold-within-6-months-of-a-cyber-attack-heres-how-to-protect-yourself.html.
11. Jacobs, Joseph, "English Fairy Tales: The Story of the Three Little Pigs," Authorama – http://www.authorama.com/english-fairy-tales-16.html.
12. NormShield, "The Intertwined Relationship Between Credit Ratings and Cyber Risk Scores After the Downgrade of Equifax Rating by Moody's," NormShield – https://normshield.com/the-intertwined-relationship-between-credit-ratings-and-cyber-risk-scores-after-the-downgrade-of-equifaxs-rating-by-moodys/.
13. Team CISO, "Cyber Security Assessments for Mergers and Acquisitions," Team CISO – https://teamciso.com/cyber-risk-assessment-for-mergers-and-acquisitions.
14. Truta, Filip, "Senator Elizabeth Warren Proposes Holding Negligent Executives Criminally Liable for Data Breaches," Security Boulevard – https://securityboulevard.com/2019/04/senator-elizabeth-warren-proposes-holding-negligent-executives-criminally-liable-for-data-breaches/.

About the Author



Mark Langford, CISSP, is the founder and principal consultant at Aberfoyle Associates, a cybersecurity consulting firm. Mark is a board member of the ISSA North Texas Chapter, earned a Master's Degree in Telecommunications Management, and may be reached at mark@aberfoyleassociates.com.

Surveying Five Years of Java Deserialization CVEs

By Erik Elbieh – ISSA member, New Jersey Chapter

A dramatic increase in Java deserialization CVEs has occurred since research in 2015 highlighted a high-impact vulnerability class that has since been found in many widely used applications. This paper examines the progress made in identifying these Java deserialization vulnerabilities and uses a custom CVE dataset to extrapolate the trajectory of this vulnerability class over the next few years.

The Java programming language has been one of the most popular programming languages for years. Starting in 2015, a flaw in a core function of the Java language—deserialization—gained substantial attention in the security community. A large number of CVEs resulted from research about deserialization, enough to place deserialization vulnerabilities into 8th position on the 2017 OWASP Top 10 Application Security Risks. While Java is not the only language in which deserialization vulnerabilities occur, Java deserialization vulnerabilities have gained widespread attention due to several factors. One factor is that Java is extremely common, as seen in figure 1, especially among enterprise applications. Another factor is that deserialization vulnerabilities are often high impact, commonly resulting in remote code execution. Lastly, it has historically been hard to detect whether a Java application is vulnerable to deserialization or not, in part because Java applications have many interconnected dependencies.

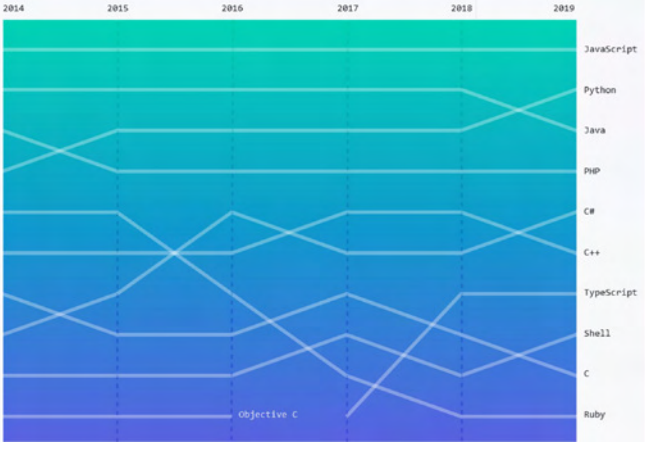


Figure 1 – GitHub report showing Java as the second-most popular language from 2014-18 [2]

Many vulnerabilities, technical research reports, and tools have been published since the 2015 presentation by Gabriel Lawrence and Chris Frohoff [1]. However, less has been written about deserialization vulnerabilities at a high level, showing the progression of this research and the direction that Java deserialization research may be heading in the future. One might ask "if 2016 was the year of the Java 'deserialization apocalypse,' where are we in 2020?" This paper aims to answer this question by examining how Java deserialization vulnerabilities and mitigations have evolved over the last five years, where we stand today, and how this vulnerability type may evolve going forward.

Introduction to Java deserialization

Programming languages often need to move *objects*—pieces of data—between locations. This includes sending data between users and a server or between different devices. Serialization is the act of converting an object into a more easily transmitted format (specifically, a byte stream), and deserialization is the opposite process, where an identical clone of the object is recreated. Note that objects can contain many different complex custom parameters, so sending objects is a more complex process than sending a primitive data type, such as a boolean or integer (int) value.

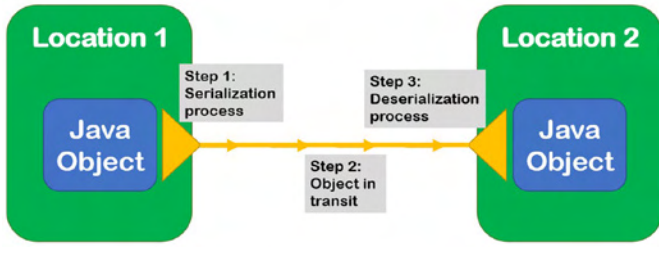


Figure 2 – Serialization enables the transfer of a Java object from one Java instance to another

A hypothetical example of serialization and deserialization occurring in Java code is shown below. Using the terminology from figure 2, the example object's "transit" is the process of being saved to a file named *mycats.txt*, while the deserialization process retrieves the file at a later time, perhaps in a different application or device. A similar process occurs when data is sent over the network, such as between a server and client.

```
// Serializing an object
Cat felixLocation1 = new Cat();
FileOutputStream exampleFileOutputStream = new
   FileOutputStream("mycats.txt");
ObjectOutputStream exampleOutputStream = new
   ObjectOutputStream(exampleFileOutputStream);
exampleOutputStream.writeObject(felixLocation1);
// Deserializing an object
FileInputStream exampleFileInputStream = new
   FileInputStream("mycats.txt");
ObjectInputStream exampleInputStream = new
   ObjectInputStream(exampleFileInputStream);
Cat felixLocation2 = (Cat)exampleInputStream.
   readObject();
```

The way that Java implements serialization makes it fairly easy to identify a serialized object. The first bytes of a serialized object, the so-called "magic bytes," appear as "ac ed" when encoded in hexadecimal or as "rO0" when encoded in Base64. These bytes are only sent at the beginning of a serialized object, so if the transfer of a serialized object is being observed (such as by a firewall) and the beginning bytes are missed, it can be harder to identify the data as a serialized object.

Java serialization is found frequently, even in standard Java features. Serialization exists in Remote Method Invocation (RMI), Java Management Extensions (JMX), Java Message Service (JMS), JavaServer Faces (JSF), and certain Spring invokers. Serialization is so pervasive in Java that it can be difficult to completely eliminate in legacy applications, which makes it hard to reduce the risk of deserialization vulnerabilities to zero.

How Java deserialization is exploited

Substantial research has been published on the topic of exploiting Java deserialization. Compared to these other works, only a brief summary of exploit methods will be discussed here. The key requirement to exploiting a Java deserialization vulnerability is modifying a serialized object, which the Java process deserializes. The user can then cause the Java process to execute arbitrary code during the deserialization process (assuming the right circumstances). There is no perfect solution for a Java application to detect whether the serialized object from the user contains harmless data or a malicious payload since the deserialization process that allows the object to be recreated and examined is the vulnerable part of the process—a catch-22 situation. This means that serialized objects from untrusted users or devices cannot be trusted.

Any detailed discussion on the exploitation of Java deserialization vulnerabilities will involve some or all of the words *gadgets* and *magic methods*. These words all relate to the creation of a specially crafted serialized object that can cause a Java process to automatically run user-specified code when the object is deserialized. It is the magic methods that are executed automatically during deserialization. The user can use magic methods to point the Java process to certain classes, or gadgets, and these classes can enable arbitrary code execution, sometimes in a multi-step "gadget chain" process, where multiple gadgets are used together. This is why many new Java deserialization vulnerabilities point out vulnerable gadgets, which are pieces of code that the serialized object can use during deserialization to exploit a deserialization vulnerability.

At a high level, the process of exploiting a deserialization vulnerability begins with a penetration tester (or a rogue actor) determining that an application is using serialized Java objects. If it is possible to manipulate and modify these serialized objects, meaning the objects are "untrusted," then it is possible to check for known vulnerabilities and perhaps return verbose error messages, providing more details about the internal workings of the Java application. If a vulnerable gadget chain is found in the application, the penetration tester can create a serialized object that contains malicious Java code, including Java code that can execute commands on the system that is running the Java application. For example, if the Java application is running on a Windows system, the command *calc.exe* could be placed inside a crafted serialized object to open the calculator program on the target Windows system. Although opening a calculator serves mainly as a demonstration that a remote code execution vulnerability exists, one can imagine a worse scenario where more harmful commands are included in a serialized object, making the remote code execution vulnerability a major risk not just to a vulnerable Java application, but to the underlying system that is running the Java application. Some of the more notable applications impacted by Java deserialization vulnerabilities include Jenkins (CVE-2015-3253), JBoss (CVE-2015-7501), Oracle WebLogic (CVE-2020-2883), and IBM WebSphere (CVE-2020-4448), among many others. The CVE score is *Critical* for all four of those CVE examples, indicating that specific versions of those applications were vulnerable to remote code execution under certain circumstances.

Deserialization vulnerabilities over time

Although 2015 was the year that Java deserialization research really increased, thanks to the work of Chris Frohoff and Gabriel Lawrence, deserialization was a known vulnerability well before that. One question that this paper seeks to answer is whether the number of Java deserialization vulnerabilities, and perhaps the risk of deserialization vulnerabilities to Java applications, peaked soon after the spike in interest around Java deserialization in 2015 and 2016. To answer this question, a dataset of published CVEs relating specifically to Java deserialization vulnerabilities was compiled. This may be the

largest dataset of Java deserialization CVEs compiled to date, and the dataset is available on GitHub [9]. Before examining the data, it is important to add clarification and outline assumptions made about the data.

While CVEs are not a perfect means to measure a quantity of vulnerabilities, they are the easiest proxy to measure and analyze. Additionally, the differences between a vulnerability's date of discovery, date of publication, and date of CVE ID assignment can make it difficult to associate a CVE to a particular year. The analysis that follows attributed each CVE to the year portion of its CVE ID (i.e., CVE-2015-7504 is associated with the year 2015). It is also likely that this dataset does not contain every single Java deserialization CVE to date, in part because the data collection process consisted of searching for CVEs containing certain serialization keywords in addition to manual filtering for unrelated CVEs, such as CVEs involving deserialization in a language besides Java. However, the dataset should suffice for observing overarching trends. With these assumptions in place, several trends relating to Java deserialization vulnerabilities were found.

Based on the collected dataset, 2016 does hold the record for the most Java deserialization CVEs reported in a single year, earning its reputation as "the year of the Java deserialization apocalypse" (figure 3). This can be attributed to the fact that the *ysoserial* Java deserialization exploit tool was released in 2015 and took some time to become widely used within the security community. Interestingly, while the number of Java deserialization CVEs has been decreasing since 2016, 2020 appears to break this downward trend. Although we are only partway through 2020, more Java deserialization CVEs were already published in 2020 than in 2019. It would not be surprising if we see the total number of Java deserialization CVEs published in 2020 end up in the range seen in the years 2016-2018.

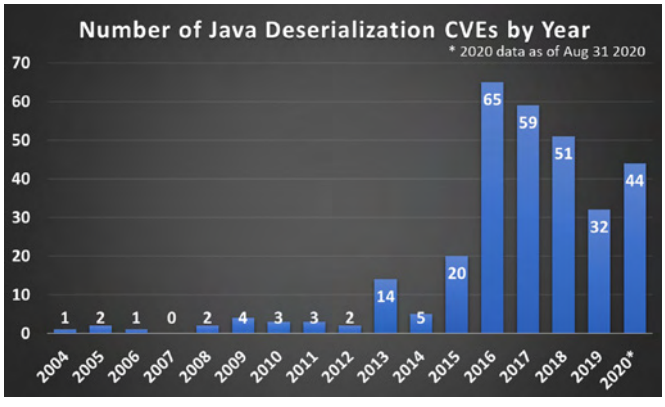


Figure 3 – Number of Java deserialization CVEs by year [9]

Another takeaway from the data is that Java deserialization vulnerabilities are frequently high or critical risk vulnerabilities. Since the introduction of CVSS 3.0 risk scoring, Java deserialization CVEs have had an average CVSS risk score of about 9 (out of a maximum of 10). While the security community has been aware of the great risks associated with Java deserialization, the fact that the average risk score associated with this vulnerability type is so high indicates that the large amount of attention this vulnerability has received is warranted. For comparison, an analysis of several thousand CVEs performed in 2016 found that CVEs had an average CVSS 3.0 risk score of 7.4 [12], and Java deserialization CVEs frequently have a score above 7 [14]. Both CVSS 2.0 and CVSS 3.0/3.1 scores are plotted to illustrate the average score over a longer period of time, since the CVSS 3.0/3.1 is a more recent version of the risk calculation formula and often results in a higher risk score than CVSS 2.0 (figure 4).

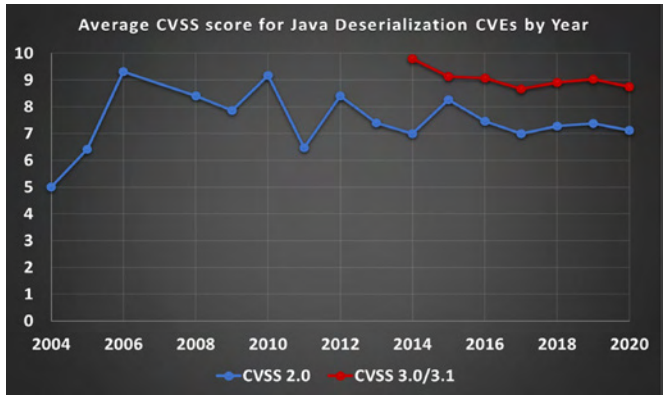


Figure 4 – Average CVSS score for Java deserialization CVEs by year [9]

Java Deserialization vulnerability detection

Although many Java deserialization vulnerabilities have been found in the last five years, the landscape of these vulnerabilities has been changing. Java libraries containing vulnerable gadgets have been patching or hardening their weak points, and developers have been taking greater care when using serialization. Oracle has pushed out several Java updates that all updated applications can benefit from. At the same time, more energy is being put into detection tools and techniques to find Java deserialization vulnerabilities now that this vulnerability type is so well-known. In the first half of 2020 alone, three new tools were published that assist with detection of Java deserialization vulnerabilities [4][5][10]. Whether this example shows a renewed interest in this specific vulnerability type or whether this is part of the broader trend of more security tools being created is unclear. However, we can anticipate that such efforts will lead to more CVEs and exploits in the next few years.

There are many tools that specialize in detecting and exploiting known Java deserialization vulnerabilities. Since even the best automated deserialization vulnerability detection approaches must deal with false positives and false negatives, it might be the case that brute forcing applications with known exploits is the easiest detection approach. However, the easiest approach is not the most thorough. If this brute force approach fails to identify a vulnerability, false negatives may lead to a false sense of security. Additionally, attempting to trigger these exploits may result in unexpected behavior on the target system, which is often not ideal during penetration tests. For now, we will look at deserialization detection methods that focus on identifying potentially vulnerable deseri-

alization exploit vectors rather than attempting known exploits. Note that simplifications of the details have been made for the purpose of brevity.

Network traffic monitoring

The first method that can be used for detecting Java deserialization vulnerabilities uses network traffic monitoring. Deserialization can be detected by searching the network traffic for either the hexadecimal "ac ed" (equivalent to "rO0" in Base64), which are the magic bytes that indicate the start of a serialized object. A related approach is searching network traffic for the HTTP Content-type header value of "application/x-java-serialized-object," which is another possible indicator that a Java serialized object is being sent. Downsides to this approach are the requirement for network traffic monitoring, and the possibility that the "ac ed" magic bytes might be missed if the start of the serialized stream occurs before the network traffic monitoring begins. Additionally, this approach only detects whether deserialization is taking place and does not give further details about how the deserialization might be exploited.

Analyzing the source code

A second method can be tried if the source code or bytecode of the Java application is available. This method consists of analyzing the source code for methods or classes that might be useful to exploit a Java deserialization vulnerability. The simplest implementation would be a simple search of the Java application's source code for known magic methods, including methods such as readObject(), readResolve(), and finalize(), among many others. Some more advanced tools in this category take a Java class or method as input and build a graph of other class or method dependencies from this input [3]. The graph can then be traversed while searching for classes or methods that may lead to Java deserialization vulnerabilities. In other words, taint analysis can be performed to determine which variables can be influenced by an untrusted user. This can lead to new gadget chains being discovered for novel exploits that would not exist among the collection of known exploits.

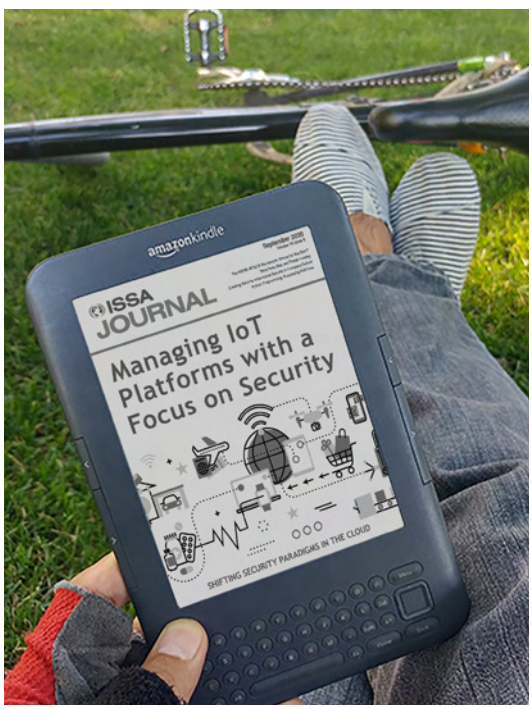
Analyze libraries and methods

A third method to detecting Java deserialization vulnerabilities is possible if network access to an application using deserialization is available, even if the application is closed source. This is the newest method that tools are being built for, as seen by three tools published in the first half of 2020 (EnumJavaLibs, GadgetProbe, and RMIScout). This approach involves using the deserialization of the target application to exfiltrate a list of libraries and methods that are in the application's classpath in order to closely examine this information for potential vulnerabilities. This method can even be used in conjunction with the second method described above, because if the libraries and methods discovered in the application are open source, the source code for these libraries can be examined using source code analysis to discover potential gadget chains or other attack vectors.

While quite a number of tools have been created to expedite the process of detecting Java deserialization vulnerabilities, there is still more work in this space to be done. Despite the efforts to automate this process so far, it still takes effort by a knowledgeable individual to determine whether a deserialization function can be exploited or not.

Mitigations against deserialization attacks

Java deserialization vulnerabilities clearly have the potential for high-risk impact. Multiple solutions have been examined to mitigate against this type of vulnerability. These solutions can be split into two categories:



The ISSA Journal on the Go!

Have you explored the versions for phones and tablets?

Go to the Journal home page and choose "ePub" or "Mobi."

Mobile Device ePubs

- ePubs are scalable to any size device: iPad/tablet provide an excellent user experience
- You'll need an ePub reader such as iBooks for iOS devices



NOTE: choose ePub for Android & iOS; Mobi for Kindles

Take them with you and read anywhere, anytime…

1. Avoiding untrusted deserialization entirely
2. Using untrusted deserialization with security hardening measures

The first option is the only sure way to prevent against this vulnerability, but we will examine both options because it can require substantial effort to remove or replace untrusted deserialization in existing applications.

If an application avoids untrusted deserialization entirely, there are still alternative approaches available that allow a client to send data to the server. For example, rather than sending a serialized object to the server, the client could transfer data using primitive data types (e.g., int, boolean, etc.) or data formats such as JSON or XML. Unfortunately, although using JSON and XML for data transfer between a client and server is better than using Java serialization, there are still ways that JSON and XML can be vulnerable to deserialization attacks [8]. It is a good rule of thumb to keep the transfer of data from client to server as simple as possible in order to properly verify that data from the client can be checked for malicious or unexpected values. In general, data sent from an untrusted client to a server should always be considered untrusted and should always be inspected and checked. As a footnote, it should be said that if both the client and server are trusted, then the risk of an untrusted deserialization exploit may be negligible. This could occur in a situation where two secure internal applications are communicating with each other and no untrusted users are involved. If it is assumed that the applications cannot be influenced by external actors, then the deserialization may be considered trusted deserialization and therefore not exploitable.

If an application is unable to remove serialization of untrusted data entirely from its codebase, hardening measures are necessary to reduce the chances of this attack surface being exploited. To be clear, the usage of untrusted deserialization, even with hardening measures, must acknowledge that the hardening measures will not be unbreakable. There are several different ways this hardening can take place. The easiest option is to search the codebase for known vulnerable gadgets or dependencies. While this test might be easier to perform, it misses the root cause at the heart of Java deserialization vulnerabilities. The vulnerability is not caused by vulnerable or poorly-coded gadgets—the gadgets only enable exploitation of deserialization vulnerabilities in certain ways. The vulnerability is the process of deserializing untrusted data. New gadgets that enable deserialization exploits continue to be published, so this method is not future-proofed against new vulnerabilities.

A slightly more effective hardening measure for applications reliant on Java deserialization is to use a whitelist to allow only "safe" deserialization or a blacklist to block "unsafe" deserialization, or both. Like the previous approach of searching for vulnerable gadgets, this whitelist or blacklist hardening measure relies on known vulnerabilities and does not consider unpublished present or future vulnerabilities. Additionally, bypasses will always be a threat with such a filter in place. Despite these limitations, Oracle incorporated whitelist and blacklist filtering into JDK 9 in January 2017 with JEP-290, and backported this update to several other JDK releases (specifically, 8u121, 7u131, and 6u141) [11]. However, one critically important point is that this JDK built-in protection requires end user configuration by setting a serialization filter [7]. This means that JEP-290 will be helpful to informed developers, but using the latest JDK will provide no benefits to uninformed developers who are unaware of the features introduced by JEP-290. In other words, the latest JDK does

ISSA International Web CONFERENCE

Click here for On-Demand Conferences

How to Discover & Mitigate APTs in Enterprise Networks
Recorded Live: September 24

Security Past, Present and Growing our Future (Together)
Recorded Live: September 21

Quantitative risk with FAIR (Security and Privacy)
Recorded Live: September 17

Driving Real Behavior Change with Security Awareness Training
Recorded Live: September 16

Human Brains for Human Problems: Successfully using ML and Automation in the SOC
Recorded Live: August 5

Moving Beyond the Potentiality of Women & Diversity in Cybersecurity
Recorded Live: August 6

Cybersecurity Career Focus – a presentation with the ISSA Education Foundation
Recorded Live: August 11

The Osano Data Privacy and Data Breach Link
Recorded Live: August 19

Can Your Security Controls Handle the Unmanaged and IoT Device Tsunami?
Recorded Live: August 26

Purple Teaming / Red Teaming and Adversary Emulation
Recorded Live: July 28

TLS, Compliance and Zero Trust: Protecting Users from Themselves
Recorded Live: July 22

Top Reopening Considerations: Back to Business with a Privacy & Security Approach
Recorded Live: July 15

A discussion presented by the Women in Security Special Interest Group
Recorded Live: July 9 @ 1:00 pm - 2:00 pm EDT (US)

Reflections of a New CISO: 5 Lessons Learned
Recorded Live: July 8

not automatically protect an application from deserialization vulnerabilities. Furthermore, a bypass to JEP-290 was published in late 2019, which was soon remediated in January 2020 by JDK 8u241 [6][15]. It is likely that the race between researchers finding JEP-290 filter bypasses and Oracle updating their filters will continue for some time (figure 5).

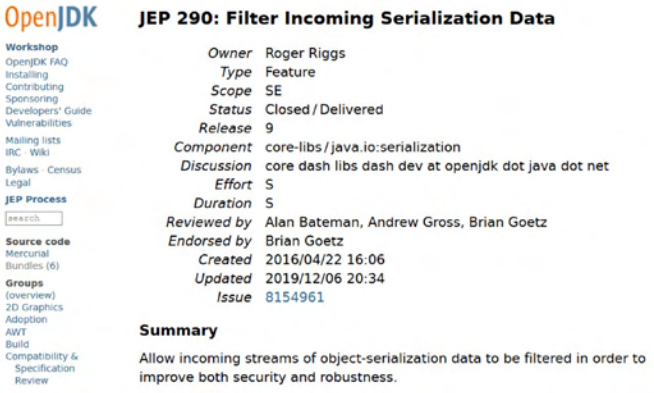


Figure 5 – JEP-290 introduced a feature to mitigate Java deserialization vulnerabilities [11]

There are other serialization protection measures, such as deserialization look-ahead functions, deserialization integrity/constraint checks, container detection controls, and Java agent instrumentation that can be used to provide additional defense-in-depth protection for untrusted Java deserialization [13]. However, while these measures can provide some amount of improvement to the risk posture of an application, they are not recommended as long-term solutions for risk-averse use cases as it is more likely that a bypass or other weakness can be found in these solutions. Despite the improvements in recent years to detect and mitigate the presence of a Java deserialization vulnerability, at the end of the day the only approach to guarantee that no Java deserialization vulnerability exists in an application is to remove untrusted serialization. Even if filtering is used and vulnerable gadgets are removed, denial of service vulnerabilities can exist even if remote code execution is not possible.

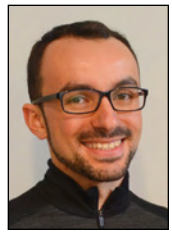
Conclusion

Given the large increase in CVEs published over the last five years, it is almost certain that deserialization vulnerabilities will continue to be found over the next five years. Competing forces are at work: on the one hand, developers are likely to become more security-conscious and better understand the security risks associated with untrusted deserialization, but on the other hand, developers are handling increasingly complex codebases and competing interests that may cause deserialization vulnerabilities to be overlooked. The methods and tools for detecting exploitable Java deserialization vulnerabilities have been improving and will continue improving in the coming years. While defense-in-depth mitigation strategies have offered some solutions to vulnerable applications, the only bulletproof mitigation of Java deserialization vulnerabilities is to remove the attack surface and avoid untrusted deserialization.

References

1. Frohoff, C. et al., "Marshalling Pickles: How Deserializing Objects Can Ruin Your Day," OWASP AppSecCali 2015, https://www.youtube.com/watch?v=KSA7vUkXGSg.
2. GitHub, "The State of the Octoverse," GitHub, https://octoverse.github.com/.
3. Haken, I. "Automated Discovery of Deserialization Gadget Chains," DEF CON 26, https://www.youtube.com/watch?v=wPbW6zQ52w8.
4. Miller, J. "GadgetProbe: Exploiting Deserialization to Brute-Force the Remote Classpath," Bishop Fox, https://know.bishopfox.com/research/gadgetprobe.
5. Miller, J. "RMIScout: Safely and Quickly Brute-Force Java RMI Interfaces for Code Execution," Bishop Fox (May 26 2020) - https://know.bishopfox.com/research/rmiscout.
6. Münch, H. "An Trinhs RMI Registry Bypass," Mogwai Labs, https://mogwailabs.de/blog/2020/02/an-trinhs-rmi-registry-bypass/.
7. Münch, H. "Attacking Java RMI Services after JEP 290," Mogwai Labs, https://mogwailabs.de/blog/2019/03/attacking-java-rmi-services-after-jep-290/.
8. Muñoz, A. et al., "Friday the 13th JSON Attacks," Black Hat USA 2017, https://www.blackhat.com/docs/us-17/thursday/us-17-Munoz-Friday-The-13th-JSON-Attacks-wp.pdf.
9. Palindrome Labs, "Java-Deserialization-CVEs," GitHub – https://github.com/PalindromeLabs/Java-Deserialization-CVEs.
10. Red Timmy Security, "Remote Java Classpath Enumeration with EnumJavaLibs," Red Timmy Security, https://www.redtimmy.com/web-application-hacking/remote-java-classpath-enumeration-with-enumjavalibs/.
11. Riggs, R. "JEP 290: Filter Incoming Serialization Data," OpenJDK, https://openjdk.java.net/jeps/290.
12. Santos, O. "The Evolution of Scoring Security Vulnerabilities: The Sequel," Cisco Blogs, https://blogs.cisco.com/security/cvssv3-study.
13. Seacord, R.C. "Combating Java Deserialization Vulnerabilities with Look-Ahead Object Input Streams (LAOIS)," NCC Group, https://www.nccgroup.com/globalassets/our-research/us/whitepapers/2017/june/ncc_group_combating_java_deserialization_vulnerabilities_with_look-ahead_object_input_streams1.pdf.
14. Soto, A. et al., "Java Serialization Objects (JSO): A Practical Exploitation Guide," Rapid7, https://www.rapid7.com/research/report/exploiting-jsos/.
15. Trinh, A. "Far Sides of Java Remote Protocols," Black Hat Europe 2019, https://www.youtube.com/watch?v=f3PXHijoP4s.

About the Author



Erik Elbieh (OSCP) is a security researcher and consultant at Palindrome Technologies. Erik enjoys penetration testing nearly anything, from web apps to cloud environments, and he partakes in CTFs whenever he can. He can be reached at erik.elbieh@palindrometech.com.

Quantitative Risk Calculation in Cybersecurity: The Value of Quantifying Risk

By Chris van den Hooven – ISSA member, Netherlands Chapter

This article advocates for the intrinsic value of quantitative decision-making in cybersecurity.

Abstract

Cybersecurity essentially reduces information-related risk to an acceptable ratio of risk to cost. The process begins with an extensive risk assessment, which is a tried and tested process that can be improved. Inspired by the work of Douglas Hubbard,[1] this article advocates for the intrinsic value of quantitative decision-making in cybersecurity.

Calculating risks

Traditional risk analysis is essentially a complex way of creating a list of things that could go wrong. The process begins by estimating both the maximum impact and the probability, and then multiplying these figures to "calculate" the risk [1].

In some cases, this works reasonably well. The (financial) risk of a laptop being stolen from a parked car can be estimated in this way. When a company owns a few thousand laptops, risk will be calculated several times per year. After a few years, the data becomes predictable; however, the value of a laptop is harder to estimate. If I ask a group of people to estimate the value of a laptop, the initial response might be in the range of the list price of the computer. If I tell them it holds the only copy of a research project someone has been working on for six weeks, the estimates inevitably rise. The estimated value might increase further once the people are aware that the laptop has shareholder information or a customer database saved on its hard drive.

Not all laptops will contain this kind of valuable information. However, these variables are often not adequately addressed in traditional IT risk management. Factor Analysis of Information Risk (FAIR) is a well-known cybersecurity risk assessment framework we can use to analyze the risk. Using the FAIR taxonomy [3] the standard risk calculation for primary risk is as follows: threat event frequency (estimation laptop is stolen) 2% (per year), vulnerability (estimation laptops containing valuable information) is 50%, the primary loss frequency is 2% x 50%=1% (per year).

The analysis associated with a simple risk calculation is elusively complex. Risks with a very high impact and a low probability are even more elusive. What if a company's data provider is hacked or goes bankrupt? The worst-case scenario the company loses all its data. However, such a scenario is highly unlikely. Contrary to that, risk is calculated using maximum impact in traditional risk analyses:

Risk = (almost zero) x (ridiculous amount of money) = nonsense

In reality, calculating risk is not so black and white. The impact of an unwanted event is not zero or maximum damage. For example, a fire in the data center usually has very localized impact, due to power supply failure. The data center is not likely to burning down to the ground, but this risk calculates the worst-case scenario. Minimal damage would incur costs of tens of thousands of euros, with the maximum breaching millions of euros. The fact that milder scenarios incurring significantly less damage are more realistic is completely ignored with traditional risk analysis.

Probability density function

A way to address the fact that there is impact variance is to assume that the probability of any amount of damage will follow a normal distribution [5]. An excellent visualization of this distribution is the Galton board.[2] The FAIR method is

1 Douglas Hubbard is a consultant and author in decision sciences and actuarial science. He is the inventor of the Applied Information Economics (AIE) method and founder of Hubbard Decision Research (HDR).

2 Visualization of the Galton Board: https://www.youtube.com/watch?v=EvHiee7gs9Y.

using quantitative algorithms. Hubbard argues that the best model for cybersecurity-related events is normal distribution on a logarithmic scale (lognormal). It represents a typical situation where risk cannot result in damage lower than zero, and although unlikely, risk can result in very serious damage [4]. Cybersecurity risks are not necessarily tangible, but they are undoubtedly part of reality.

Two points must be plotted to calculate the curve. To ensure that it is as simplified as possible, the 90 percent confidence interval is chosen. A confidence interval, as defined by Hubbard, refers to the probability that a population parameter will fall between two set values for a certain proportion of times. Confidence intervals measure the degree of uncertainty or certainty in a sampling method.

This means we can estimate a lower and upper bound of the expected damage in nine out of 10 events. For instance, in nine out of 10 times, the cost of a stolen laptop is between €2000 and €50k (figure 1). To estimate the upper and lower bound, Hubbard encourages us to use all data available. However, even small samples are valuable.

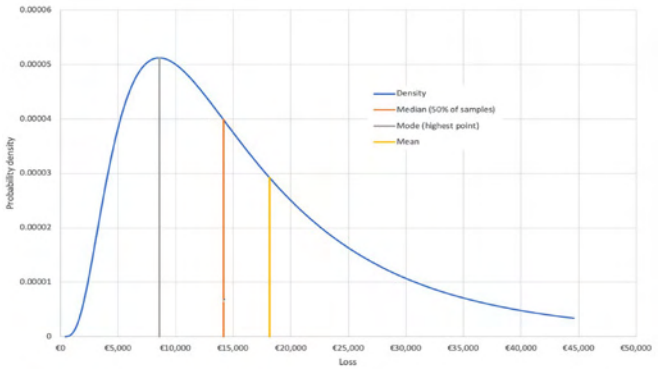


Figure 1 – Lognormal probability density

In analyzing just five samples, the probability that the median[3] value is between the highest and lowest sampled value is already 90 percent [4]. The median loss in this example is about €31,600. If there were at least five laptops stolen last year, at least one of them is expected to have caused lower damage, and at least one of them is expected to have caused more serious damage. If this is not the case, we should probably adjust the upper and lower bounds.

When applied to the stolen laptop example, the risk can now be defined as:

Risk = (2% chance per year a laptop is stolen) x (90% probability the impact is between 1,000 and 25,000 euro)

A giant data leak may occur, resulting in millions of damages when a single laptop is stolen. The probability, however, is very low (less than five percent).

Risk is now defined as a change or probability of damage instead of an absolute amount of money. In my opinion, this reflects the reality because we can predict the course of the impact of events happening, but we cannot predict the impact of individual events. People who play the lottery will "win" about half of the money they pay for their tickets, but the chance of someone winning the jackpot is minuscule.

How to use the probability density function

The probability that an event will happen (likelihood) is measured in one percentage point over one year. Therefore, a 10 percent likelihood means we expect the event to happen once every ten years.

When historical data is available, we are obliged to use it. Luckily, it is possible to access data from similar situations or similar companies, and we are not limited to our own datasets. When an event happens twice in three years within a sample group of seven companies, we know the event's probability of occurring is about 2/(3x7)=9.5%. (This figure is fact-based, not an estimation.) However, there might be a considerable deviation with these small numbers. When only one event had occurred, we would have calculated a probability of 4.75%. There is some room for fine-tuning the parameters.

The expected loss per year for this risk is calculated by combining the curve and likelihood. There is an expected loss of €12,300 per year in our example.[4] Calculating the expected loss before and after applying a security control is one way to measure the yield of the implemented control.

Choosing probability density function parameters

Since the expected loss is based on the upper and lower bound and the probability of loss, there are many ways to choose these parameters resulting in the same expected loss. If we have historical data about the annual loss, we can use it to adjust the parameters.

For example, consider the following options where we vary the lower bound, and the probability of loss to keep the Expected Loss remains fairly constant (table 1).

90% Confidence Interval	Curve 1	Curve 2	Curve 3	Curve 4
Lower Bound	€2,000	€10,000	€20,000	€100,000
Upper Bound	€500,000	€500,000	€500,000	€500,000
Median	€31,623	€70,711	€100,000	€223,607
Probability of event occurring	9.50%	8.50%	7.60%	4.85%
Expected loss	€12,287	€12,189	€12,266	€12,224

Table 1 - 90% confidence interval

These parameters result in the probability density distributions in figure 2.

3 The median value is by definition the value any sample has a probability of 50% being lower and 50% being higher than the median. The chance five consecutive random samples are all higher is 50%x50%x50%x50%x50%=3.125%. All samples lower is another 3.125%, leaving 100%-2x3.125%=93.75% chance the median is between the samples. On a logarithmic scale, this is applied to ln(value).

4 If interested: There is a very good explanation of the calculation at Stack Exchange (Mathematics section) – https://math.stackexchange.com/questions/1878357/how-to-interpret-this-excel-formula-for-expected-loss.

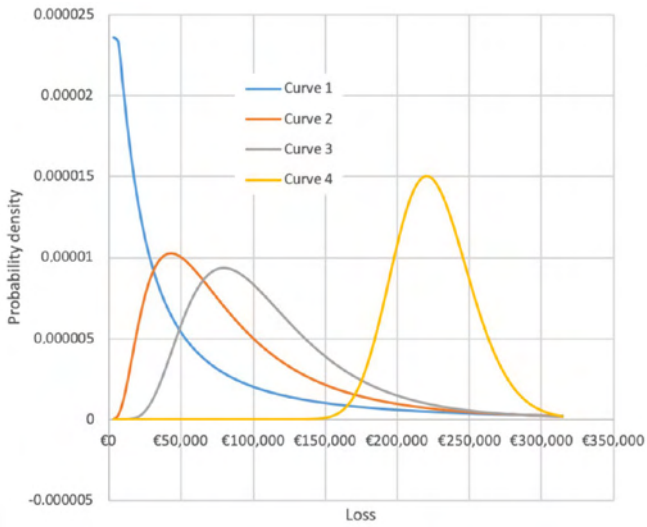


Figure 2 – Varying the lower bound and probability of loss

Each curve models a different situation. The blue line models a condition with many laptops imposing relatively low damage when stolen. The yellow curve models a case with many laptops inflicting relatively serious damage when stolen. The expected loss is similar because the effect is compensated by the probability the event will happen (see table 1). However, the difference is quite big (9.5% vs. 4.85%), and the yellow line is probably too extreme in our example.

The blue line, however, is quite extreme too. This is due to the upper and lower bound being so far apart. Hubbard warns for unrealistic outcomes if the spread between the upper and lower bound of the confidence interval is too large [4].

Suppose five or more laptops were stolen, and at least one of the cases the damage was greater than €70,711 and at least one case resulting in damage lower than that. These cases would fit the orange curve, which has a lower bound of €10,000 instead of €2000. We probably underestimated the lower bound.

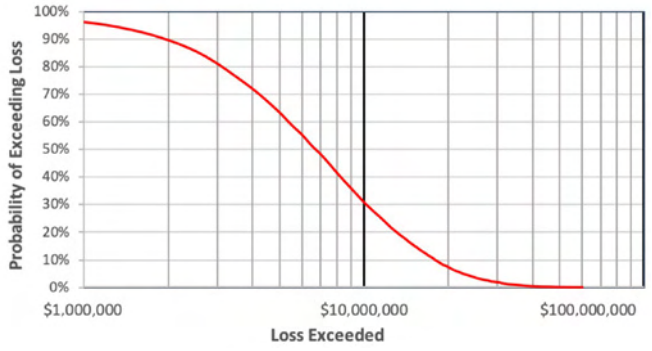


Figure 3 – Loss exceeded curve

Aggregating risks

Once a list of risks is compiled, and the upper and lower bounds of damage are estimated, we can aggregate the risk. This is done to incorporate multiple types or sources of risk. The most common approach is to estimate the amount of "economic capital" that a company believes is necessary to absorb potential losses associated with each of the included risks. In other words, companies aggregate the damages to yield a total amount of damage to one random situation.

Two things are calculated for every risk: the probability that damage will be incurred and the probability density function when damage is incurred. Random scenarios are often created for this purpose. Table 2 reflects such a hypothetical scenario (column "Random Result").

If we repeat this exercise frequently enough, we can more accurately predict probable damage. This method is called a Monte Carlo Analysis [2].

Let's say this is done 10,000 times, yielding the same number of 10,000 different results. From these it is possible to calculate how probable it is that the total incurred damage will exceed a certain threshold. A typical graphic representation of this is presented in figure 3.

The sample graph illustrates the probability of excessive annual loss. In the example, there is a 30 percent probability that losses will exceed €10,000,000. The probability that it exceeds €1,000,000 is above the 90th percentile. By implementing extra security measures, we can reduce risk and recreate the graph. In doing so, we can compare various scenarios and evaluate the investment versus the reduced risk. Using these kinds of graphics, it becomes easier to discuss IT risks with boards and C-suite executives.

#	Event	Probability	Low	High	Random Result
R1	Personal identifiable information of clients is leaked because the database "X" is hacked	5%	€ 4,000,000	€ 10,000,000	€ 0
R2	Personal identifiable information of employees is leaked because the HRM system is hacked	5%	€ 4,000,000	€ 10,000,000	€ 0
R3	Personal identifiable information of employees is leaked because of human error while emailing	25%	€ 10,000	€ 40,000	€ 9,679
R4	Personal identifiable information of clients is sent to wrong partner because of human error	25%	€ 40,000	€ 400,000	€ 150,471
R5	Confidential research information is leaked because the researcher loses a USB stick	25%	€ 10,000	€ 40,000	€ 0

Table 2 – Risk events

Business Impact Reference Table	1 = Negligible	2 = Low	3 = Moderate	4 = High
Financial impact	<10K	<40K	<400K	<4M
Operational impact - technology	<1 hour unavailable	1-2 days unavailable	3-5 days unavailable	>5 days unavailable
Operational impact - people	No personal identifiable information involved	Personal identifiable information from a few people involved	Systematic leakage of personal identifiable information	Deliberate leakage of personal identifiable information
Reputational impact	No impact	Clients stop cooperating	Clients and suppliers stop cooperating	Clients and suppliers stop cooperating, license to operate is revoked by government
Likeliness	5%	25%	35%	50%

Table 3 – Business impact reference table (BIRT)

A practical example comparing the methods

Some time ago, I performed a risk assessment with a company that employs a few hundred people and is a digital service provider. An evaluation is conducted every year, starting with a risk identification session where management, including the CEO, is present.

The traditional approach

The first step taken in this situation is defining the business impact reference table (BIRT). Here the negligible-low-mid-high levels of the impact and likeliness are explicitly listed. Not only does this table define categories in monetary value, it also "translates" operational and reputational value to monetary value (table 3).

#	Event	Impact	Chance	Risk
R1	Personal identifiable information of clients is leaked because the database "X" is hacked	4	1	4
R2	Personal identifiable information of employees is leaked because the HRM system is hacked	4	1	4
R3	Personal identifiable information of employees is leaked because of human error while emailing	2	2	4
R4	Personal identifiable information of clients is sent to wrong partner because of human error	3	2	6
R5	Confidential research information is leaked because the researcher loses a USB stick	2	2	4
R6	Confidential research information is leaked because the researcher makes a mistake when emailing	2	3	6
R7	Personal identifiable information of clients is leaked because the database "Y" is hacked	3	1	3
R8	Personal identifiable information of clients is leaked because the database "Z" is hacked	2	1	2

Table 4 – Risks and estimations of impact and likeliness

The second step is to identify risks and estimations of impact and likeliness using the BIRT as a reference. Likeliness and impact were chosen according to the table and the risk was calculated as *impact* multiplied by *likeliness*. The participants were asked to rank the risks in terms of importance. After some discussion, the team came up with the inventory in table 4 (truncated list).

What is striking is that the actual impact that risks have is not congruent with how participants perceived them. For example, risks R1 and R2 were identified by the team as the two most harmful risks, while calculations show risks R4 and R6 to be most harmful to their company.

LOOKING AHEAD

November: Big Data/Machine Learning/ Adaptive Systems

Artificial intelligence, machine learning, predictive analytics are the latest buzzwords in information security in the areas of antivirus and threat detection. It is possible that new methods based upon AI, deep learning, and analytics may be incorporated into adaptive controls and countermeasures that can better address the more complex threat environment we now face?

December: Looking toward the Future of Infosec

It's time to pull out the crystal ball for a glimpse at the future of information security. Will next year be the year that AI, neural nets, and machine learning can anticipate zero-day attacks? Will we ever sort out an individual's right to control access to his or her data? What will new disruptive technologies look like, and how will they impact us?

#	Event	Probability	Low	High	Expected loss
R1	Personal identifiable information of clients is leaked because the database "X" is hacked	5%	€ 4,000,000	€ 10,000,000	€ 328,735
R2	Personal identifiable information of employees is leaked because the HRM system is hacked	5%	€ 4,000,000	€ 10,000,000	€ 328,735
R3	Personal Identifiable information of employees is leaked because of human error while emailing	25%	€ 10,000	€ 40,000	€ 5,464
R4	Personal identifiable information of clients is sent to wrong partner because of human error	25%	€ 40,000	€ 400,000	€ 40,400
R5	Confidential research information is leaked because the researcher loses a USB stick	25%	€ 10,000	€ 40,000	€ 5,464
R6	Confidential research information is leaked because the researcher makes a mistake when emailing	35%	€ 10,000	€ 40,000	€ 7,650
R7	Personal Identifiable information of clients is leaked because the database "Y" is hacked	5%	€ 40,000	€ 400,000	€ 8,080
R8	Personal identifiable information of clients is leaked because the database "Z" is hacked	5%	€ 10,000	€ 40,000	€ 1,093

Table 5 – Case study results

The quantitative approach

Damage is not fixed in any given incident but can vary in size. To estimate the distribution, we work with a 90 percent confidence interval (this entails defining a lower and upper bound of damage considered valid for 90 percent of the cases). For this case study, we use the boundaries of the categories as defined in the BIRT. The results can be found in table 5.[5]

These outcomes are a much more accurate reflection of the team's expectations. Risks R1 and R2 are identified as the main risks, making the other risks seem much less relevant.

In this case the expected loss to the organization, or the losses the business is likely to incur annually due to the identified risk, was €750,000. This estimation was far from accurate (annual loss over the years was in a range below €100,000), which substantiates the argument to use quantitative analysis to achieve more accurate risk estimates.

Why calculation matters

A company will generally have a budget for these losses as a part of the standard operating cash flows, meaning that by minimizing expected loss, capital can be allocated to other investments.

Estimating an annual loss using the traditional risk assessment is challenging and inaccurate. In cybersecurity calculating "maximum damages" multiplied by "likeliness" does not always produce a constructive figure. In many cases quantitative risk analysis gives you more realistic results while using the same data. It will provide organizations with insight into projected losses, which can be used to fine-tune the estimates of likeliness and 90 percent confidence interval of impact. However, there are exceptions. Freund gives a good example: "For some kinds of risk analyses, we specifically target the tails in order to do some stress testing ("what if" testing such as if all events occurred today in their worst-case form)" [3]. Once risks are better understood, mitigation can be developed more effectively, thereby improving the return on investment for cybersecurity.

5 Because there is no lower bound defined for category "negligible" and no upper bound for category "high" we have to add those. Objective values of 1,000€ for the lower bound and 10,000,000€ for the upper bound were assigned.

References

1. Aven, T., (2011). *Quantitative Risk Assessment: The Scientific Platform*. Universitet I Stavanger, 9780511974120.
2. Bonate, P.L., "A Brief Introduction to Monte Carlo Simulation," Clinical Pharmacokinetics, 40 (1) (2001) – 10.2165/00003088-200140010-00002.
3. Freund, J. and J. Jones, *Measuring and Managing Information Risk: A FAIR Approach*, Butterworth-Heinemann (2014).
4. Hubbard, D.W., *How to Measure Anything in Cybersecurity Risk*, Wiley (2016), 9781119085294.
5. Montgomery, D.C. and Runger, G.C., Applied Statistics and Probability for Engineers (6th ed.), Wiley (2014), 9781118743959.

About the Author



Chris van den Hooven is a senior security consultant, Nixu Corporation. Chris has a 15-year track record in translating business risks into appropriate measures in the field of information security and has held several information security and risk management positions before joining Nixu. He may be reached at Chris.vandenHooven@nixu.com.

Meet the Next Generation of Cybersecurity Women

Continued from page 6

hood. Along with the Nintendos, there was surely Google, which just blew me away! I always used to search on Google, and it was very eye catching for me to see how using just a few key words could bring me so many articles. It is surely a big reason why I am in the field of computer science.

I did envision myself in cybersecurity growing up. There was a period of time where I wanted to major in cybersecurity. I was actually inspired by a show that was based on cybersecurity and cybercrimes. There was also a time when I wanted to study cyber-forensics. Later, I started watching Google I/O, the annual conference hosted by Google, and the technological advancements just made me want to be on that stage presenting the state of the art technologies. It was just very personal to me, and it is still is a dream to be on the stage during Google I/O and present the new technology that millions of people are looking forward to. Who knows who I might inspire one day!

I was fortunate to have many STEM courses growing up in India. I had a computer science course for every year in my middle and high school. It was very interesting for me as we used to code and develop websites and software in class, which revealed what coding can do. These opened a whole new world of possibilities. I was always the girl with a perfect grades; sports never interested me. I have won Olympiads and spelling bee competitions and have been a part of student body government. I always enjoyed geeky things, and I loved the computer science courses throughout my school life."

How they got to where they are today

Joanna: I got to where I am today by not listening to stereotypes that dictate computers and math are for boys and that women should revert to other stereotypical callings. There is empowerment being a woman in a male-dominated field!

Also, I have a knack for basic problem solving, which is important in this field. I have noticed that I find different ways to solve algorithms than most people. I have begun to develop that skill more efficiently, but communicating/people skills are traits that are also needed more in this field. I am trying to grow my analytical brain with practice, but also hold onto the ability to not only communicate with just computers, but also humans as well.

Yatri: I think the skill of mine to go behind what I want and not to settle for anything else is what has helped me get where I am currently. I evaluate every step I am about to take and judge if that is going to help me achieve what I want or not, and then decide if that particular thing is worth investing my time and effort into. I have always made all the decisions myself, so I do think that has also influenced where I am currently.

Another thing which I realized was that I often got bored doing the same thing, and computer science was new every single day. I discovered I needed something new or a new challenge every single day to keep myself engaged. I enjoy algorithm development and the amazing things I can do with just a few lines of code.

With this, I once again went on Google and researched my way ahead into the field. I searched for colleges with the computer science courses; I looked at the course descriptions. It there were descriptions I didn't understand, I searched again. It was a recurring process of research and getting interested in the field.

Role models, mentors, and influencers

Joanna: Yes, I do have a role model and mentor. I remember walking into one of my classes and being incredibly intimidated after reading the accomplishments of this certain professor. Then Dr. Campbell strolled into class. You see, most of the teachers are male. Dr. Campbell perfectly describes this balance of what I described above. Her course changed the way I thought previously. Even amidst the pandemic, she made time to call and check on me; I was pretty devastated after COVID hit. My entire way of learning was jolted, and I was fired from my job. It got pretty low, but she gave me the encouragement I needed and helped me find a way to balance COVID and classes.

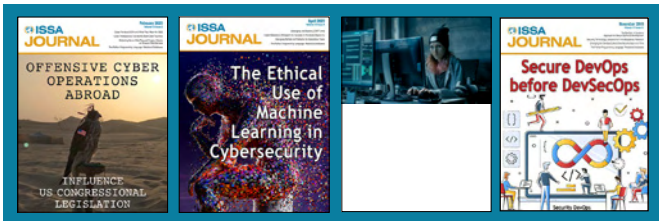
Yatri: As role models, I have my parents who have taught me to dream big and work for it. That one lesson is so deep inside me that I just cannot stop working and trying to achieve my dreams.

I don't know if there is a single role model or mentor of mine; it's more like I learn from every biography I read, every interview I read or watch, every person I meet. I believe it needs to vary, depending on at what point you are in your life; and that is exactly what has happened with me. I have been inspired by well-known people in the field, by my professors, and by my fellow classmates. I have learned something from everyone.

There are surely a few people I look up to. One is Steve Jobs. His vision brought Apple to the position it is currently in. Second is Sundar Pichai. He has climbed his way up to the position of CEO at Google. He is the person who inspires me to be on top of my game 24X7. Elon Musk, who thinks big and ahead of time, has taught me not to be afraid to think big and dream big and work to make it a reality.

I feel that there are not many women role models in the field of tech, but recently I have come across a few very strong and tech-concentrated women leaders. Ginni Rometty, the former CEO of IBM, is a woman who has led IBM through the transition period when it was moving towards being a data company. She has made decisions that have influenced IBM's technology a lot.

Then I read about Ursula Burns, who was the first woman of color to serve as a CEO for a fortune 500 company. She



ISSA Journal 2020 Calendar

Past Issues – digital versions: click the download link:

JANUARY
Best of 2019

FEBRUARY
Regulation, Public Policy, and the Law

MARCH
Preparing the Next Generation Security Professional

APRIL
Corporate and Nation-State Cybersecurity: Attack and Defense

MAY
Practical Cryptography and the Quantum Menance

JUNE
The Infosec Toolbox: Basics to the Bleeding Edge

JULY
Security vs Privacy Tug of War

AUGUST
Disruptive Technologies

SEPTEMBER
Shifting Security Paradigms in the Cloud

OCTOBER
The Business Side of Security
Editorial Deadline 9/10/20

NOVEMBER
Big Data/Machine Learning/Adaptive Systems
Editorial Deadline 10/1/20

DECEMBER
Looking toward the Future of Infosec
Editorial Deadline 11/1/20

For theme descriptions, visit www.members.issa.org/page/CallforArticles.

EDITOR@ISSA.ORG • WWW.ISSA.ORG

was a normal woman who attended a normal college, not a Stanford or Harvard, and she made her way to the position of CEO. She has been an inspiration to me, being bold, outspoken, and down to earth, fighting against all the odds. She inspires me to continue working on myself, and maybe one day all the fights will be over and I will be successful in my field of choice and inspire others just like her. The article "Against the Odds: Ursula Burns' Extraordinary Rise to the Top" is what always motivates me to stand up and be better.[1]

Advocating for women to enter the field

Joanna: We all want to think that stereotypes don't exist, but they do, sadly. Boys are given video games and girls are given dolls to play with. I grew up around video games, so the fascination started early for me. I was called a copious number of names for being more of a "nerd" who played with computers and PlayStation rather than dresses and dolls. Obviously, I paid no attention to it. My brothers were a big influence on my love for computers, and I have often wondered if I would be here learning computer science if my brothers didn't exist.

Physiologically, women have some advantages to men, and vice versa. With differing genetic make-up comes differing ideas and perspectives; since this is such a male-dominated field, women can offer much needed perception changes and contrary philosophies, especially since some countries still don't allow women to study or succeed. We can allow women to be present at the round table! We just need more of them in this field!

My advice to women wanting to enter the field is "don't listen to stereotypes that computers and math are for boys, and that women should revert to other stereotypical callings. There is empowerment being a woman in a male-dominated field!"

Yatri: I think the main reason more women are not entering the field lies in the natural tendencies of men and women, which is topped with the existing disparity and lack of role models in the field of computing for women. I had never heard of a woman who had made a major contribution in the field of computer science till I went into college in 2017. Even when they make achievements, they are never in the spotlight to inspire others. Another factor that I think is affecting this disparity is inclusivity—a culture that includes women in the work environment in CS. I have seen more women switching to management positions rather than continuing in the computer science world than men. Women leave technology companies at twice the rate of men. All these discourage women to pursue careers in tech.

I am fortunate to have been raised by my parents without any stereotypes, even though in my grandparents' generation there were and still are stereotypes for girls. My parents have always introduced me to all the options for me from the beginning, I was given both video games and dolls. I was always told that there is nothing that a girl can't do, and I can achieve whatever I want.

1 Katsomitros, Alex. "Against the Odds: Ursula Burns' Extraordinary Rise to the Top," World Finance – https://www.worldfinance.com/markets/against-the-odds-ursula-burns-extraordinary-rise-to-the-top.

I believe the number one way any woman can make a difference in any tech field, from cybersecurity to development, is by inspiring other women and taking the time and effort to open the world of tech to young girls.

Thoughts on getting hired in the field

Joanna: In other majors, I have noticed a gap between earning a degree and getting hired in the field. So yes, I think there is somewhat of a discrepancy in earning a degree and seeking employment, but computer science is one field that seems to have an array of job openings. This was a factor in my deciding to make the switch over to the computer science and cybersecurity world.

While I have not had a chance to work in the field as an intern or other role, I have had some amazing teachers reach out to me about internship and work study programs. There always seems to be a need for computer programmers at differing levels.

Yatri: I do think there is a small gap between earning a degree and getting hired, especially if you have big ambitions. The gap between earning a degree and getting hired can be made easier by clearly stating the interview process and deadlines on the website, as you never know the deadline when you apply unless you have attended a seminar by them. By stating a clear recruitment process, it makes an already stressful process easier. Another thing that I think could be done is streamlining the process so when you graduate you apply to a lot of companies; and it gets messy when you are keeping track of all those applications.

Today's recruiters skim resumes for an average of 7.4 seconds. Hence, it does become hard to impress a person by your resume within a span of 10 seconds. I do believe that spending more time on each person might not be feasible for the company, but as an applicant, it does sound a bit unfair. From my personal experience applying for a summer internship in Goldman Sachs, I did very well on my coding round, but I still got rejected, so sometimes the recruiting process can be unfair and can leave out the people who are actually good.

Contrary to the system in the United States, almost all the colleges in India have a placement system. Changing colleges between India and America has been a challenge for me. Looking for jobs and adjusting to the academic system in another country, which you are not at all familiar with, has been my biggest obstacle. It is not something I have overcome yet, as I am still unfamiliar with a lot of different procedures when it comes to applying and looking for jobs.

On future roles they envision

Joanna: I have not pin-pointed a specific interest or organization, but rather, several. The very element of multiplicity among jobs inspires me to explore all areas of this challenging, mesmerizing land of computer science. There are offshore coders who program from a beach in Hawaii; project managers who inspire teams; IT sales professionals who sell technology; and that doesn't even begin to scratch the surface of possibilities this major has to offer.

Yatri: After graduation, I am planning on joining either tech, finance, or consultancy firms. I do have a list of dream companies that I would love to work for. To name a few I would say, Google, Netflix, Morgan Stanley, JP Morgan Chase, Goldman Sachs, McKinsey & Co. They all have different challenges, but in particular I would love to work at the front end with clients as a business analyst trying to help the clients to improve their business model using my data science skills. I want to work in a position where I can see my work impacting the clients or the customers in a positive way.

Conclusion

Just as the workplace is changing, the mind-set of the new generation of cybersecurity and computer science women is changing. Joanna Rachel and Yatri Patel are two bright stars who focus on solutions rather than failures. They choose to forge full-steam ahead in a once male-dominated field, looking out for ways to succeed and inspire others along the way.

One thing is for certain. Joanna and Yatri know how to manage change, respond to change, and drive change as their passions, interests, and education move ahead. They represent a new generation, one that knows how to value and leverage diversity in skills and experiences to achieve superior results. With Joanna and Yatri, I see bright futures and succession planning for developing new leaders in cybersecurity.

About the Author

Dr. Curtis C. Campbell is VP of Atlantic Capital Bank in Atlanta, GA, and a recently elected International Board Director. She also serves as ISSA Chattanooga Chapter president. Curtis holds a PhD in organizational leadership in information systems technology and serves on the advisory board of University of TN-Chattanooga. Connect with Curtis via curtis@mprotechnologies.com.



2019 Journal – Past Issues

Past Issues – digital versions: click the download link:

Best of 2018 | Legal & Public Policy
Cloud | Infosec Basics
Cryptography | Privacy
Internet of Things | The Toolbox
Information Security Standards
The Business Side of Security
Security DevOps | Looking Forward

18

Python Programming: Object-Oriented Programming

By Constantinos Doskas – ISSA Senior Member, Northern Virginia Chapter

This article is an introduction to object-oriented technology. Python is an object-oriented language. Up to this point we have used many of the objects provided by Python, although our programming approach was procedural. What is object-oriented programming? Why was it developed? Why do we want to use it? These are questions that will be answered in this and the next few articles.

Some history

Computer technology entered our life in the early 1800s with the Jacquard Loom machine, which was inspired by previous inventions. However, devices that aid people in calculations were in use even in ancient times and are part of the process that led to the development of the digital electronic computers that are used today. Generally, there are two categories of computing devices: mechanical and electrical. Furthermore, they are divided into analog and digital. Some analog computers are used even to this day, but digital computers have dominated the computational field.

A pivotal invention in the history of digital computers was the development of the UNIX operating system at Bell Labs. One major contributor to the development of the UNIX system is Dennis Ritchie who also developed the C programming language. All computer operating systems and programming languages are based on these two inventions, the UNIX operating system and the C programming language. The next invention that is directly related to our topic was the development of C++ by Bjarne Stroustrup in 1980. Next, Java was developed by James Gosling at Sun Microsystems in the early 1990s. Java is based on C/C++ but has a more simplified object model than C++. In addition. while C and C++ code is compiled to produce an executable program, Java is not compiled but interpreted, In 1991 Guido van Rossum created Python, an object-oriented programming language like C++, interpreted like Java, and emphasizing code readability.

Why OOP

Object-oriented programming (OOP) has several advantages over procedural programming. One of them is *information hiding*. According to this concept information is accessible only to its owner. OOP also implements the concept of *modular programming* better than procedural methodologies. Another advantage of OOP is the true implementation of the concept of objects. Imagine an object, for instance, the engine of a car. The engine consists of many modules/objects assembled together and working together flawlessly. Some of these objects are the main engine block, pistons, valves, injectors, etc. Another example is the animal. Animals consist of a head, main body, legs, tail. Each of these parts (objects in our discussion) has unique functionalities and can be broken down to smaller parts (objects). The head of an animal, for instance, consists of ears, eyes, nose, mouth, brain. Each of these sub-objects has its own functionality. To fully describe objects like an animal, OOP implements the concept of polymorphism. Back to our example, all animals have a head, however, the head of each species of animal has its own unique shape and special features. Take for instance the eyes of the animals. Each specific animal group has eyes with some common capabilities to another animal group and some unique capabilities.

When building a very complex program with thousands or millions of lines of code, troubleshooting becomes very difficult. In OOP all programs consist of smaller program units connected together. These smaller program units are much easier to troubleshoot.

I think this quick overview of the OOP methodology is enough for us to start our voyage into OOP program development. In future articles we will examine in detail the four pillars of the object-oriented methodology: Encapsulation, data abstraction, polymorphism, and inheritance.

Basic OOP concept

The basis of OOP is the concept of the *class*. Classes are like templates or rubber stamps. Consider a rubber stamp with the word "Paid" on it. It is made once and used many times. Each time the rubber stamp is used, it is considered an instantiation of the class. Take another example, the cookie cutter. The cookie cutter is made once and then it creates cookies every time it is used.

A class consists of variables and functions. The variables of a class can only be accessed by the functions built in the class. In OOP we call the variables of a class *attributes* or *properties*. The functions that belong to a class are called *methods* or *behaviors*. In our animal example, eat, run, and sleep are *behaviors*, while age, weight, and color are *attributes*.

Classes implement the notion of *this* or *self,* which is a reference to the object itself. Classes have a special method **__init__**, which is called the *constructor*, although some like to call it the *initiator*. Note that when a class is instantiated, the constructor is executed first with the data that is provided and initializes the newly created object.

Here is an example of a simple class in Python.

```
class network_device:
def __init__(self, name):
      self.name=name
# -- Class instantiation
# -- 1) Switch object
switch1 = network_device('CISCO switch')
print(switch1.name)
# -- 2) Router object
router1 = network_device('CISCO ASA 5506 router')
print(router1.name)
# -- 3) Router object
router2 = network_device('Netgear AC1750 router')
print(router2.name)
```

Here is the output of the print statements:

CISCO switch

CISCO ASA 5506 router

Netgear AC1750 router

Discussion

The code above creates a class named **network_device**. This class has a constructor __init__ which takes the following arguments; *self* and *name*. The code **switch1 = network_device('CISCO switch')** creates the first object named switch1, which is named CISCO switch and that value is saved in switch1's attribute *name*. Note that the *attribute* is preceded by the word *self,* which means that this *attribute* is only known to the object. The following print statement **print(switch1.name)** prints the value of attribure *name* which is CISCO switch. The following instructions create two more objects, *router1* and *router2,* and print the value stored in their *name* attribute.

The next example shows a class with multiple arguments in the constructor.

```
# -- Class section
class network_device:
def __init__(self, mfg, device_type, device_model,
   banner_onOff):
self.mfg=mfg
self.device_type=device_type
self.device_model=device_model
self.banner_onOff=banner_onOff

# -- Class instantiation
# -- 1) Switch object
switch = network_device('CISCO','switch','222',False)
print("Network Element: ",switch.device_type)
print("Manufactured By: ",switch.mfg)
print("Model: ",switch.device_model)
print("Banner display enabled? ",switch.banner_onOff)
```

Here is the output of the print statement:

Network Element: switch

Manufactured By: CISCO

Model: 222

Banner display enabled? False

Discussion

Note that in the above example banner_onOff is set to *False*, This is the proper initialization of the banner property of a network element that is hardened against hacker attacks. Let us now create a *method/behavior* that is able to access the internal variables of the class. At this time we will introduce some error checking in the *constructor* and in the *method/behavior*. Here is the code:

```
# -- Class section
class network_device:
def __init__(self, mfg,device_type, device_model,\
banner_flag : bool):
self.mfg=mfg
self.device_type=device_type
self.device_model=device_model
       if banner_flag==True or banner_flag==False:
           self.banner_onOff=banner_flag
       else:
           self.banner_onOff=False
   def set_banner(self,setting : bool):
       if setting==True or setting==False:
           self.banner_onOff=setting
       else:
           print("Error Wrong Argument Type\n",\
           "Banner must be set to True or False")
# -- Class instantiation
# -- 1) Switch object
switch = network_device('Cisco','switch','222',"test")
print("Network Element: ",switch.device_type)
```

```
print("Manufactured By: ",switch.mfg)
print("Model: ",switch.device_model)
print("Banner display enabled? ",switch.banner_onOff)
switch.set_banner(2.9)
print("Banner display enabled? ",switch.banner_onOff)
```

Here is the output of the print statement:

Network Element: switch

Manufactured By: Cisco

Model: 222

Banner display enabled? False

Error Wrong Argument Type

Banner must be set to True or False

Banner display enabled? False

Discussion

Note that the function *set_banner()* can modify the internal attribute *banner_onOff*. The allowable values of that flag are *True* or *False*. The statement ***if setting==True or setting==-False*** is screening the input to the function for a correct value. If the value is not *True* or *False,* then an error is printed on Python's shell.

The next example demonstrates the creation of a class that produces a bar chart out of given data.

```
# -- Class section
class create_visualization_bargraph:
def __init__(self,supertitle,title,xlabel,ylabel,
          xvalues,yvalues):
self.suptitle=supertitle
self.title=title
self.xlabel=xlabel
self.ylabel=ylabel
self.xvalues=xvalues
self.yvalues=yvalues
def create_bar_chart(self):
import matplotlib.pyplot as plt
plt.bar(xvalues,yvalues,width=0.2,align='edge',color=
       (0.6,0.7,0.1,0.8)
 label='CVEplt.xlabel(self.
   xlabel['AxisLabel'],color=self.
   xlabel['color'],fontsize=self.xlabel['fontsize']) # --
   Creats x axis labels and colors them
 plt.ylabel(self.ylabel['AxisLabel'],color=self.
   ylabel['color'],fontsize=self.ylabel['fontsize'])
   plt.suptitle(self.suptitle['Label'],color=self.
   suptitle['color'],\
 fontsize=self.suptitle['fontsize'],ha=self.
   suptitle['location'])
   plt.title(self.title['Label'],fontsize=self.
   title['fontsize'],\
 loc=self.title['location'],color=self.title['color'])
   plt.show()
# -- Data Preparation
supertitle_dict= {'Label':'VULNERABILITY
   ANALYSIS','color':'darkblue','fontsize':14,'location':
          'center'}
title_dict={'Label':'By Year','color':'blue','fontsize':14,
          'location':'center'}
xlabel_dict={'AxisLabel':'Years','color':'brown','fontsize'
          :13,'location':'center'}
ylabel_
   dict={'AxisLabel':'Vulnerabilities','color':'brown',
          'fontsize':13,'location':'center'}
xvalues=(2010,2011,2012,2013,2014,2015,2016,2017,2018,2019)
yvalues=(1000,954, 435, 326, 755, 611,1590,1045, 854, 916)
# -- Class instantiation
unix_plot=create_visualization_bargraph(supertitle_
   dict,
title_dict,
xlabel_dict,
ylabel_dict,
xvalues,
yvalues)
unix_plot.create_bar_chart()
```

Discussion

The above code creates a class that produces bar charts. We can use that object to bar chart NVD data that we have stored in the SQLite database we created in previous articles. In this example we hard coded values that could be produced from the NVD database and stored in the tuple objects *xvalues*, *yvalues*.

Note that the arguments that provide data to the class are dictionaries and tuples, which are themselves objects. Last year we explained how dictionaries, lists, and tuples are organized and utilized. The dictionaries used in this example (supertitle, title, xlabel, and ylabel) have hard coded values and predefined keys. The values could come from a GUI or web app, which could act as a control panel of this program.

The method/behavior **def create_bar_chart(self):** produces a bar graph out of values that are stored in the class during initialization. The first statement in that class imports the library matplotlib. Hint – if running the program produces an error message related to this library, then you must download the library and install it. We have given to the object *matplotlib.pyplot* the name *plt*. That object, *plt*, has a multitude of attributes and we are using a subset of them. For each one of these attributes we created a corresponding key in our dic-

The Open Forum

The Open Forum is a vehicle for individuals to provide opinions or commentaries on infosec ideas, technologies, strategies, legislation, standards, and other topics of interest to the ISSA community. Articles should be around 850 words and include a short bio and photo. Please submit to editor@issa.org.

tionaries. Then we are using these keys to extract their values from the dictionary and feed them to the *plt* object.

Example:

```
title_dict={'Label':'By Year',...
plt.title(self.title['Label']...
```

When the label value is transferred from title_dict to plt.title object we have:

```
plt.title('By Year',…
```

Also note that we left hard coded the highlighted attributes of the **plt.bar** object:

```
plt.bar(xvalues,yvalues,width=0.2,align='edge',color=
        (0.6,0.7,0.1,0.8))
```

These values may also be provided to the object through additional arguments either through the constructor or the **create_bar_chart(self)**: behavior itself. I will leave that to you as an exercise. Figure 1 is the output of the program.

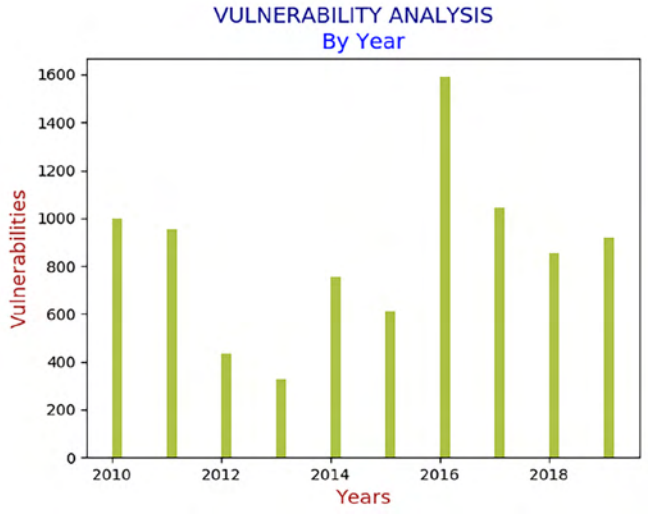


Figure 1 – Vulnerability analysis by year

What is in the next article

This article and a next few articles are just a parenthesis to our discussion of NVD data processing. In the next article we will continue the discussion on OOP features, advantages, and disadvantages. Our examples will still be cybersecurity related and our goal is to be able to continue processing NVD data once we have acquired a solid understanding of the OOP methodology.

Conclusion

To conclude, OOP methodology has a lot of advantages over procedural programming methodology. Python is an OOP-based language and can be used to develop programs in either of the two methodologies. This article introduced the concept of classes and objects. We discussed the __init__ function of a class and how to create attributes and behaviors. Finally, we examined how built-in objects and objects that we create can work together to provide a solution. The solution may be of technical or financial nature. However, since OOP is able to successfully "recycle" code, it is a perfect financial approach for our organizations since it enables us to fix bugs quickly, costs less, and re-use code, resulting in programming time savings.

Download the code of this article from the ISSA website and stay safe at home developing your programming skills. Use your imagination and create something disruptive. See you again through the next article,

About the Author



Constantinos Doskas is head of the IT and Security Department of Olympus. He has been involved in information systems management and development for over 30 years. He is currently involved in mentoring graduate students and ISSA members in Northern Virginia. He may be reached at cdoskas@ofdcorp.com.

ISSA CAREER CENTER

The ISSA Career Center offers a listing of current job openings. Among the current job listings [9/29/2020] are the following:

- **Adjunct Professor, Networking** – Collin College, TX
- **Instructor, Cybersecurity** – Flatiron School, Washington, DC
- **Cybersecurity Leadership Opportunities** – City of Toronto, Toronto, ON
- **Information Security Analyst III** – Ohio University, Athens, OH
- **Information Security Engineer** – Creighton University, Omaha, NE
- **Senior Information Security Analysts** – American Express, Phoenix, AZ
- **Cloud Information Security Specialist** – Federal Reserve Bank of New York, New York City, NY
- **Information Security Analysts** – American Express, Phoenix, AZ
- **Information Security Sys Spec** – Columbia University, NY
- **Information Security Manager** – American Express, New York, NY
- **Information Security Analyst** – Editas Medicine, Cambridge, MA
- **Information Security Manager (DevSecOps)** – Quorum, Washington, DC
- **Information Technologies Security Officer** – City of Oceanside, Oceanside, CA
- **Information Security Manager** – Travelodge, Thame, South West England, United Kingdom

netwrix



POWERFUL DATA SECURITY MADE EASY

Netwrix solutions empower organisations to surface risk without adding another layer of complexity. Know where your sensitive data resides and identify security gaps at a glance to mitigate the risk of a data breach and ensure regulatory compliance.

www.netwrix.com